



Introducción a la Ciberseguridad

Teoría básica para principiantes

MARTIN ALBERTO BENITES MARIN
CISCO



Tabla de contenido

INTRODUCCIÓN A LA CIBERSEGURIDAD	4
El mundo de la Ciberseguridad	4
Datos de la Organización	7
Ciberatacantes	11
ATAQUES, CONCEPTOS Y TÉCNICAS	14
Tipos de malware.....	14
Síntomas del malware.....	17
Métodos de infiltración	17
Ingeniería social.....	17
Denegación de servicio	18
DoS distribuido	18
Botnet.....	19
Ataques en el camino	20
Envenenamiento SEO	21
Ataques de contraseña	21
Amenazas persistentes avanzadas	22
Aprovechamiento de las vulnerabilidades de seguridad	23
Vulnerabilidades de hardware	23
Vulnerabilidades de software	24
Categorización de vulnerabilidades de software	24
Actualizaciones de software	25
El panorama de la ciberseguridad	26
Criptomonedas.....	26
Criptojacking.....	27
PROTEGIENDO SUS DATOS Y SU PRIVACIDAD	27
Proteja sus dispositivos y su red	27
Protegiendo sus Dispositivos Informáticos	27
Seguridad de la red inalámbrica en casa	29
Riesgos del Wi-Fi público	29
Una Contraseña Segura	30
Uso de una frase de contraseña.....	30
Guías para las contraseñas.....	31
Mantenimiento de Datos	31
¿Qué es la encriptación?	31
¿Cómo se cifran sus datos?	32

Realice un respaldo de sus datos	32
¿Cómo se eliminan sus datos de forma permanente?	33
¿A quién le pertenecen sus datos?	34
Términos del servicio	34
Comprenda los términos.....	34
Antes de registrarse	34
Proteja sus datos	34
Protección de la privacidad en línea	35
Autenticación en Dos Factores.....	35
Autorización abierta	35
Social Sharing (compartir en redes sociales)	36
Privacidad de correo electrónico y navegadores web	36
PROTEGIENDO A LA ORGANIZACIÓN	37
Dispositivos de Ciberseguridad y Tecnología	37
Dispositivos de seguridad	37
Cortafuegos (firewalls)	37
Análisis de puertos.....	38
Sistemas de detección y prevención de intrusiones	39
Detección en tiempo real	40
Protección contra software malicioso	41
Mejores prácticas de seguridad.....	42
Enfoque de comportamiento de ciberseguridad	43
Seguridad basada en el comportamiento.....	43
NetFlow	43
Pruebas de Penetración	44
Reducción del impacto	45
¿Qué es la gestión de riesgos?	46
Enfoque de Cisco para la ciberseguridad.....	47
CSIRT de Cisco	47
Libro de estrategias de seguridad.....	49
Herramientas para la prevención y la detección de incidentes	49
¿SU FUTURO ESTARÁ RELACIONADO CON LA CIBERSEGURIDAD?.....	50
Cuestiones legales y éticas	50
Cuestiones legales en Ciberseguridad	50
Cuestiones éticas en ciberseguridad	51
Educación y carreras.....	52

Certificaciones profesionales.....	52
------------------------------------	----

INTRODUCCIÓN A LA CIBERSEGURIDAD

El mundo de la Ciberseguridad

¿Qué es la Ciberseguridad?

La ciberseguridad es el esfuerzo continuo para proteger a las personas, las organizaciones y los gobiernos de los ataques digitales mediante la protección de los sistemas y datos en red contra el uso o daño no autorizados. Tanto a nivel de:

- **Telepresencia:** A nivel personal, debe proteger su identidad, sus datos y sus dispositivos informáticos.
- **Organizacional:** A nivel corporativo, es responsabilidad de todos proteger la reputación, los datos y los clientes de la organización.
- **Gubernamental:** A medida que se recopila y comparte más información digital, su protección se vuelve aún más vital a nivel gubernamental, donde la seguridad nacional, la estabilidad económica y la seguridad y el bienestar de los ciudadanos están en juego.

Según normativas peruana:

“Capacidad tecnológica de preservar el adecuado funcionamiento de las redes, activos y sistemas informáticos y protegerlos ante amenazas y vulnerabilidades en el entorno digital. Comprende la perspectiva técnica de la Seguridad Digital y es un ámbito del Marco de Seguridad Digital del país.”

Recopilado de: <https://cdn.www.gob.pe/uploads/document/file/2790485/Decreto%20de%20Urgencia%20N%20007-2020.pdf?v=1643322610>

Protegiendo su Data Personal

Los datos personales son cualquier información que se puede utilizar para identificarlo y puede existir tanto fuera de línea como en línea.

Identidad fuera de línea: Su identidad fuera de línea es la persona de la vida real que presenta a diario en casa, en la escuela o en el trabajo. Como resultado, familiares y amigos conocen detalles sobre su vida personal, incluidos su nombre completo, edad y dirección. Es importante no pasar por alto la importancia de proteger su identidad sin conexión. ¡Los ladrones de identidad pueden robar fácilmente tus datos justo debajo de tus narices cuando no estás mirando!

Identidad en línea: Su identidad en línea no es solo un nombre. Es quién eres y cómo te presentas a los demás en línea.

Incluye el nombre de usuario o alias que utiliza para sus cuentas en línea, así como la identidad social que establece y representa en las comunidades y sitios web en línea. Debe tener cuidado de limitar la cantidad de información personal que revela a través de su identidad en línea.

Su identidad en línea

Al elegir un nombre de usuario, es importante no revelar ninguna información personal.

Otros consejos útiles para ayudarte a generar tu nombre de usuario:

- No utilices tu nombre completo ni partes de tu dirección o número de teléfono.
- No utilices tu nombre de usuario de correo electrónico.
- No utilices la misma combinación de nombre de usuario y contraseña, especialmente en las cuentas financieras.
- No elijas un nombre de usuario muy extraño y luego lo reutilices una y otra vez, ya que hace que sea más fácil rastrearlo.
- No elijas un nombre de usuario que dé pistas sobre tus contraseñas, como una serie de números o letras, la primera parte de una frase de dos partes, como knock-knock o starlight, o el departamento en el que trabajas, como TI.
- Elija un nombre de usuario que sea apropiado para el tipo de cuenta, es decir, empresarial, social o personal.

Su data

Los datos personales describen cualquier información sobre usted, incluido su nombre, número de seguro social, número de licencia de conducir, fecha y lugar de nacimiento, nombre de soltera de su madre e incluso fotos o mensajes que intercambia con familiares y amigos.

Los ciberdelincuentes pueden utilizar esta información confidencial para identificarlo y hacerse pasar por usted, lo que infringe su privacidad y puede causar graves daños a su reputación.

¿Dónde están sus datos?

Esto te ha hecho pensar. Ayer mismo, usted compartió un par de fotos de su primer día de trabajo con algunos de tus amigos cercanos. Pero debería estar bien, ¿verdad? ¡Veamos!

- Tomó algunas fotos en el trabajo con su teléfono móvil. Las copias de estas fotos ahora están disponibles en su dispositivo móvil.
- Los compartiste con cinco amigos cercanos, que viven en varios lugares del mundo.
- Todos tus amigos descargaron las fotos y ahora tienen copias de tus fotos en sus dispositivos.
- Uno de tus amigos estaba tan orgulloso que decidieron publicar y compartir tus fotos en línea. Las fotos ya no están solo en tu dispositivo. De hecho, han terminado en servidores ubicados en diferentes partes del mundo y personas que ni siquiera conoces ahora tienen acceso a tus fotos

Robo de identidad

No contentos con robar su dinero para obtener ganancias financieras a corto plazo, los ciberdelincuentes invierten en la ganancia a largo plazo del robo de identidad.

- Robo médico: El aumento de los costos médicos ha provocado un aumento en el robo de identidad médica, y los ciberdelincuentes roban seguros médicos para usar los beneficios para ellos mismos. Cuando esto sucede, cualquier procedimiento médico llevado a cabo en su nombre se guardará en su historia clínica.
- Banca: El robo de datos privados puede ayudar a los ciberdelincuentes a acceder a cuentas bancarias, tarjetas de crédito, perfiles sociales y otras cuentas en línea. Armado con esta información, un ladrón de identidad podría presentar una declaración de impuestos falsa y cobrar el reembolso. Incluso podrían solicitar préstamos a su nombre y arruinar su calificación crediticia (y también su vida).

¿Quién más quiere mis datos?

No solo los delincuentes buscan sus datos personales.

- **Proveedor de servicios de Internet:** Su ISP hace un seguimiento de su actividad en línea y, en algunos países, puede vender estos datos a los anunciantes con fines de lucro. En ciertas circunstancias, es posible que los ISP tengan la obligación

legal de compartir su información con las agencias o autoridades de vigilancia del gobierno.

- **Anunciantes:** La publicidad dirigida forma parte de la experiencia de Internet. Los anunciantes monitorean y rastrean sus actividades en línea, como los hábitos de compra y las preferencias personales, y envían anuncios dirigidos a su manera.
- **Motores de búsqueda y plataformas de redes sociales:** Estas plataformas recopilan información sobre su género, geolocalización, número de teléfono e ideologías políticas y religiosas en función de sus historiales de búsqueda y su identidad en línea. Luego, esta información se vende a los anunciantes con fines de lucro.
- **Sitios web que visita:** Los sitios web utilizan cookies para rastrear sus actividades con el fin de brindar una experiencia más personalizada. Pero esto deja un rastro de datos que está vinculado a su identidad en línea que a menudo puede terminar en manos de los anunciantes.

Datos de la Organización

Tipos de datos de la organización

Datos Tradicionales

Los datos tradicionales suelen ser generados y mantenidos por todas las organizaciones, grandes y pequeñas. Incluye lo siguiente:

- **Datos transaccionales**, como detalles relacionados con la compra y venta, actividades de producción y operaciones organizativas básicas, como cualquier información utilizada para tomar decisiones de empleo.
- **La propiedad intelectual**, como patentes, marcas registradas y planes de nuevos productos, permite a una empresa obtener una ventaja económica sobre sus competidores. Esta información a menudo se considera un secreto comercial y perderla puede resultar desastroso para el futuro de una empresa.
- **Los datos financieros**, como las declaraciones de ingresos, los balances y las declaraciones de flujo de caja brindan información sobre el estado de la empresa.

Internet de las cosas (IoT) y Big Data

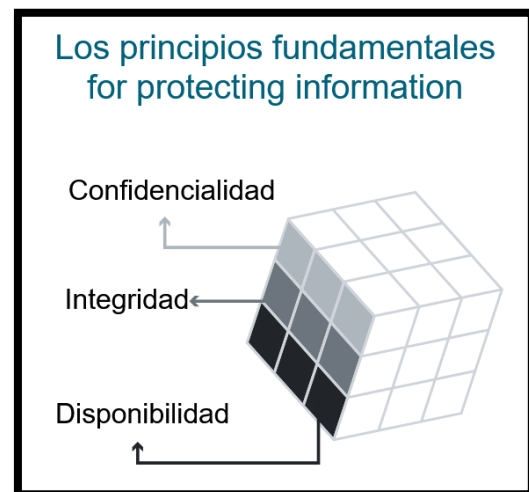
IoT es una gran red de objetos físicos, como sensores, software y otros equipos. Todas estas «cosas» están conectadas a Internet, con la capacidad de recopilar y compartir datos.

Y dado que las opciones de almacenamiento se están expandiendo a través de la nube y la virtualización, no sorprende que la aparición de IoT haya llevado a un crecimiento exponencial de los datos, creando una nueva área de interés en tecnología y negocios llamada «Big Data».

El cubo

El McCumber Cube es un marco modelo creado por John McCumber en 1991 para ayudar a las organizaciones a establecer y evaluar iniciativas de seguridad de la información al considerar todos los factores relacionados que las afectan. Este modelo de seguridad tiene tres dimensiones:

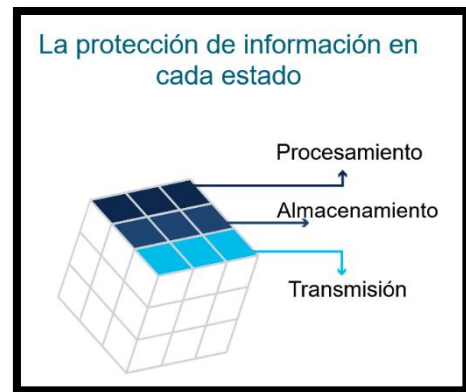
1. Los principios fundamentales para proteger los sistemas de información.
 2. La protección de la información en cada uno de sus estados posibles.
 3. Las medidas de seguridad utilizadas para proteger los datos.
- **La confidencialidad** es un conjunto de reglas que evita que la información sensible sea revelada a personas no autorizadas, espacio de recursos y procesos. Los métodos utilizados para garantizar la confidencialidad incluyen el **cifrado** de datos, **la autenticación** y el **control de acceso**.
 - La integridad garantiza que la información o los procesos del sistema estén protegidos contra modificaciones intencionales o accidentales. Una forma de garantizar la integridad es utilizar una función **hash** o **suma** de comprobación.
 - **La disponibilidad** significa que los usuarios autorizados pueden acceder a los sistemas y datos cuando y donde sea necesario y aquellos que no cumplen con las condiciones establecidas, no lo son. Esto se puede lograr **mediante el** manteniendo el equipo, **realizando reparaciones de hardware, manteniendo los sistemas operativos y el software actualizados, y creando copias de seguridad.**



✚ El procesamiento se refiere a los datos que se utilizan para realizar una operación como la actualización de un registro de base de datos (datos en proceso).

✚ El almacenamiento se refiere a los datos almacenados en la memoria o en un dispositivo de almacenamiento permanente, como un disco duro, una unidad de estado sólido o una unidad USB (datos en reposo).

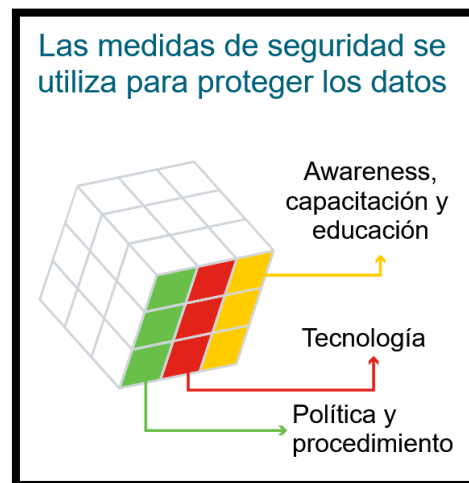
✚ La transmisión se refiere a los datos que viajan entre sistemas de información (datos en tránsito).



▪ **La concientización**, la capacitación y la educación son las medidas implementadas por una organización para garantizar que los usuarios estén informados sobre las posibles amenazas a la seguridad y las acciones que pueden tomar para proteger los sistemas de información.

▪ **La tecnología** se refiere a las soluciones basadas en software (y hardware) diseñadas para proteger los sistemas de información como los firewalls, que monitorean continuamente su red en busca de posibles incidentes maliciosos.

▪ **La política y el procedimiento** se refieren a los controles administrativos que proporcionan una base para la forma en que una organización implementa el aseguramiento de la información, como los planes de respuesta a incidentes y las pautas de mejores prácticas.



Las consecuencias de una Violación a la Seguridad

Daño a la reputación: Una violación de la seguridad puede tener un impacto negativo a largo plazo en la reputación de una organización que ha tardado años en construirse. Los clientes, en particular aquellos que se han visto afectados negativamente por la infracción, deberán ser notificados y pueden solicitar una compensación y/o recurrir a un competidor

confiable y seguro. Los empleados también pueden optar por irse a la luz de un escándalo. Dependiendo de la gravedad de una infracción, puede llevar mucho tiempo reparar la reputación de una organización.

Vandalismo: Un hacker o un grupo de hackers pueden vandalizar el sitio web de una organización publicando información falsa. Incluso pueden hacer algunas modificaciones menores en el número de teléfono o la dirección de su organización, que pueden ser más difíciles de detectar. En cualquier caso, el vandalismo en línea puede mostrar falta de profesionalismo y tener un impacto negativo en la reputación y credibilidad de su organización.

Robo: Una violación de datos suele implicar un incidente en el que se han robado datos personales confidenciales. Los ciberdelincuentes pueden hacer pública esta información o explotarla para robar el dinero y/o la identidad de una persona.

Pérdida de ingresos: El impacto financiero de una violación de la seguridad puede ser devastador. Por ejemplo, los hackers pueden eliminar el sitio web de una organización y evitar que haga negocios en línea. La pérdida de información del cliente puede impedir el crecimiento y la expansión de la empresa. Puede exigir una mayor inversión en la infraestructura de seguridad de una organización. Y no olvidemos que las organizaciones pueden enfrentarse a grandes multas o sanciones si no protegen los datos en línea.

Propiedad intelectual dañada: Una brecha de seguridad también podría tener un impacto devastador en la competitividad de una organización, particularmente si los hackers pueden tener acceso a documentos confidenciales, secretos comerciales y propiedad intelectual.

Las organizaciones deben invertir en prácticas de seguridad mejoradas. Esto puede incluir lo siguiente:

- Invertir en capacitación en ciberseguridad para todo el personal para que conozcan y puedan detectar un ciberataque.
- Hacer cumplir la autenticación de dos factores para los empleados que acceden a archivos y aplicaciones que contienen datos confidenciales.
- Mantenimiento de archivos de registro y monitoreo continuo para identificar comportamientos anómalos que puedan indicar una violación de datos.

- Almacenar las contraseñas de los clientes mediante una combinación de algoritmos de salado y hash robustos.
- Separar los recursos basados en la nube de la Internet pública en un segmento de red privada aislada.
- Conceder a los empleados acceso a los datos personales y a los sistemas internos solo a través de una conexión VPN segura.

Una violación de la seguridad es un incidente que provoca el acceso no autorizado a datos, aplicaciones, servicios o dispositivos, lo que expone información privada que los atacantes pueden utilizar para obtener beneficios económicos u otras ventajas. Sin embargo, hay muchas maneras de protegerse a sí mismo y a su organización. Es importante estar al tanto de las ciberamenazas comunes y mantenerse alerta para que no se convierta en la próxima víctima.

Ciberatacantes

Los atacantes son personas o grupos que intentan aprovechar las vulnerabilidades para obtener una ganancia personal o financiera. Como ya hemos visto, están interesados en **todo**, desde tarjetas de crédito hasta diseños de productos.

Tipos de atacantes

Echemos un vistazo a algunos de los principales tipos de ciberatacantes que intentarán cualquier cosa para obtener nuestra información. A menudo se les clasifica como atacantes de sombrero **blanco**, sombrero **gris** o sombrero **negro**.

Aficionados

El término «niños de guiones» surgió en la década de 1990 y se refiere a hackers aficionados o sin experiencia que utilizan herramientas o instrucciones existentes en Internet para lanzar ataques. Algunos script kiddies son simplemente curiosos, otros están tratando de demostrar sus habilidades y causar daño. Si bien estos atacantes de «niños de guiones» pueden usar herramientas básicas, sus ataques aún pueden tener consecuencias devastadoras.

Hackers

Este grupo de atacantes irrumpe en sistemas informáticos o redes para obtener acceso. Dependiendo de la intención de su intrusión, pueden clasificarse como hackers de sombrero blanco, gris o negro.

- Los **atacantes de Sombrero Blanco** ingresan a las redes o los sistemas informáticos para descubrir las debilidades para poder mejorar la seguridad de estos sistemas. Estas intrusiones se realizan con el permiso previo y los resultados se informan al propietario.
- Los **atacantes de Sombrero Gris** pueden proponerse encontrar vulnerabilidades en un sistema, pero solo informarán de sus hallazgos a los propietarios de un sistema si hacerlo coincide con su agenda. O incluso podrían publicar detalles sobre la vulnerabilidad en Internet para que otros atacantes puedan aprovecharla.
- Los **hackers de Sombrero Negro** aprovechan las vulnerabilidades para obtener un beneficio personal, financiero o político ilegal.



Hackers organizados

Estos atacantes incluyen organizaciones de ciberdelincentes, hacktivistas, terroristas y piratas informáticos patrocinados por el estado. Suelen ser muy sofisticados y organizados, e incluso pueden proporcionar ciberdelito como un servicio a otros delincentes.

Los hacktivistas hacen declaraciones políticas para crear conciencia sobre temas que son importantes para ellos.

Los atacantes patrocinados por el estado reúnen inteligencia o sabotean en nombre de su gobierno. Por lo general, están altamente capacitados y bien financiados, y sus ataques se centran en objetivos específicos que son beneficiosos para su gobierno.

Amenazas internas y externas

Los ciberataques pueden originarse tanto dentro de una organización como fuera de ella.

Interna

Los empleados, el personal contratado o los socios de confianza pueden, de forma accidental o intencionada:

- manejar mal los datos confidenciales
- facilitar ataques externos conectando medios USB infectados al sistema informático de la organización
- invitar malware a la red de la organización haciendo clic en correos electrónicos o sitios web maliciosos
- amenazar las operaciones de servidores internos o dispositivos de infraestructura de red

Externas

Los atacantes aficionados o expertos fuera de la organización pueden:

- aprovechar las vulnerabilidades de la red
- obtener acceso no autorizado a dispositivos informáticos
- utilizar la ingeniería social para obtener acceso no autorizado a los datos de la organización

Guerra Cibernética

La principal razón para recurrir a la guerra cibernética es obtener ventaja sobre los adversarios, ya sean naciones o competidores.

Para recopilar información comprometida y/o secretos de defensa: Una nación u organización internacional puede participar en una guerra cibernética para robar secretos de defensa y recopilar información sobre tecnología que ayudará a reducir las brechas en sus industrias y capacidades militares. Además, los datos confidenciales comprometidos

pueden dar a los atacantes una ventaja para chantajear al personal dentro de un gobierno extranjero.

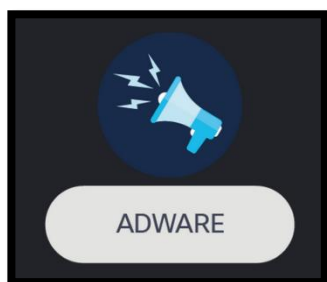
Para impactar la infraestructura de otra nación: Además del espionaje industrial y militar, una nación puede invadir continuamente la infraestructura de otra nación para causar trastornos y caos. Por ejemplo, un ataque puede afectar la red eléctrica de una ciudad importante. Considere las consecuencias si esto sucediera; las carreteras estarían congestionadas, el intercambio de bienes y servicios se detendría, los pacientes no podrían recibir la atención que necesitarían si ocurriera una emergencia, el acceso a Internet se vería interrumpido. Al cerrar una red eléctrica, un ciberataque podría tener un enorme impacto en la vida cotidiana de los ciudadanos comunes.

ATAQUES, CONCEPTOS Y TÉCNICAS

Tipos de malware

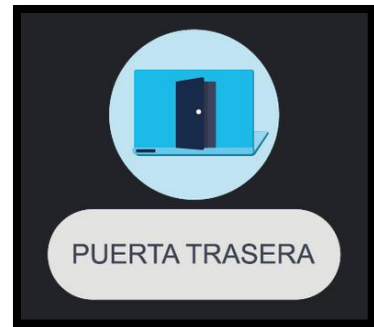
Los ciberdelincuentes utilizan muchos tipos diferentes de software malicioso, o malware, para llevar a cabo sus actividades. El malware es cualquier código que se puede utilizar para robar datos, eludir los controles de acceso o causar daño o comprometer un sistema. Saber cuáles son los diferentes tipos y cómo se propagan es clave para contenerlos y eliminarlos.

Spyware: Diseñado para rastrearlo y espiarlo, el software espía monitorea su actividad en línea y puede registrar cada tecla que presiona en el teclado, así como capturar casi todos sus datos, incluida información personal confidencial, como sus datos bancarios en línea. El software espía lo hace modificando la configuración de seguridad de sus dispositivos. El spyware con frecuencia se agrupa con el software legítimo o con caballos troyanos.



Adware: El adware a menudo se instala con algunas versiones de software y está diseñado para entregar automáticamente anuncios a un usuario, la mayoría de las veces en un navegador web. ¡Lo sabes cuando lo ves! Es difícil ignorarlo cuando te enfrentas a anuncios emergentes constantes en tu pantalla. Es común que el adware venga con spyware.

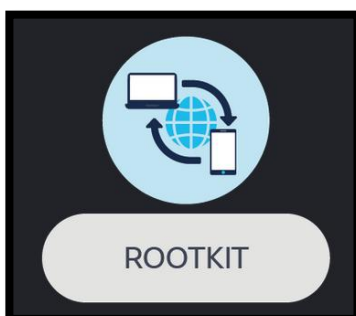
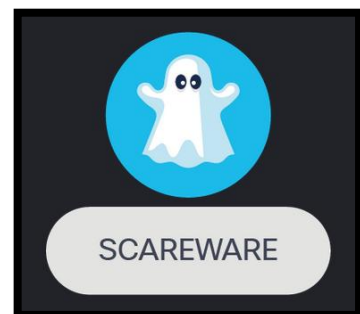
Puerta trasera: Este tipo de malware se utiliza para obtener acceso no autorizado al omitir los procedimientos de autenticación normales para acceder a un sistema. Como resultado, los hackers pueden obtener acceso remoto a los recursos de una aplicación y emitir comandos remotos del sistema. Una puerta trasera funciona en segundo plano y es difícil de detectar.



Ransomware: El malware está diseñado para mantener cautivo un sistema computacional o los datos que contiene hasta que se realice un pago. El ransomware generalmente funciona cifrando sus datos para que no pueda acceder a ellos. Algunas otras versiones de ransomware pueden aprovechar vulnerabilidades específicas del sistema para

bloquearlo. El ransomware a menudo se propaga a través de correos electrónicos de phishing que lo alientan a descargar un archivo adjunto malicioso o a través de una vulnerabilidad.

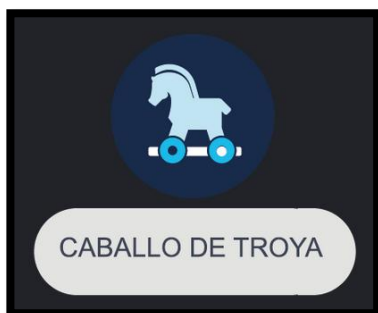
Scareware: Este es un tipo de malware que utiliza tácticas de «miedo» para engañarlo para que tome una acción específica. El scareware consiste principalmente en ventanas emergentes que aparecen para advertirle que su sistema está en riesgo y necesita ejecutar un programa específico para que vuelva a funcionar normalmente. Si acepta ejecutar el programa específico, su sistema se infectará con malware.



Rootkit: Este malware está diseñado para modificar el sistema operativo para crear una puerta trasera, que los atacantes pueden usar para acceder a su computadora de forma remota. La mayoría de los rootkits aprovecha las vulnerabilidades de software para ganar acceso a recursos que normalmente no debería ser accesibles (escalada de

privilegios) y modificar los archivos del sistema. Los rootkits también pueden modificar las herramientas de monitoreo y análisis forense del sistema, lo que los hace muy difíciles de detectar. En la mayoría de los casos, un equipo infectado por un rootkit debe borrarse y reinstalarse cualquier software necesario.

Virus: Es un tipo de programa informático que, cuando se ejecuta, se replica y se adjunta a otros archivos ejecutables, como un documento, insertando su propio código. La mayoría de los virus requieren la interacción del usuario final para iniciar la activación y se pueden escribir para que actúen en una fecha u hora específica. Los virus pueden ser relativamente inofensivos, como los que muestran una imagen divertida. O pueden ser destructivos, como los que modifican o eliminan datos. Los virus también pueden programarse para mutar a fin de evitar la detección. La mayoría de los virus ahora se esparcen por unidades USB, discos ópticos, recursos de red compartidos o correo electrónico.



Troyano: Este malware lleva a cabo operaciones maliciosas al enmascarar su verdadera intención. Puede parecer legítimo, pero, de hecho, es muy peligroso. Los troyanos aprovechan sus privilegios de usuario y se encuentran con mayor frecuencia en archivos de imagen, archivos de audio o juegos. A diferencia de los virus, los troyanos no se replican a sí mismos, sino que actúan como señuelo para colar software malicioso a los usuarios desprevenidos.

Gusano: Este es un tipo de malware que se replica a sí mismo para propagarse de un ordenador a otro. A diferencia de un virus, que requiere un programa anfitrión para ejecutarse, los gusanos pueden ejecutarse por sí mismos. Aparte de la infección inicial del host, no requieren la participación del usuario y pueden propagarse muy rápidamente por la red. Los gusanos comparten patrones similares: aprovechan las vulnerabilidades del sistema, tienen una forma de propagarse y todos contienen código malicioso (carga útil) para dañar los sistemas informáticos o las redes. Los gusanos son responsables de algunos de los ataques más devastadores en Internet. En 2001, el gusano Code Red había infectado más de 300.000 servidores en solo 19 horas.



Síntomas del malware

Independientemente del tipo de malware con el que se ha infectado un sistema, estos son síntomas frecuentes de malware. Entre ellos se encuentran:

- un aumento en el uso de la unidad de procesamiento central (CPU), lo que ralentiza el dispositivo
- el equipo se congela o se bloquea con frecuencia
- una disminución en la velocidad de navegación web
- problemas inexplicables con las conexiones de red
- archivos modificados o eliminados
- una presencia de archivos, programas o iconos de escritorio desconocidos.
- se ejecutan procesos o servicios desconocidos
- los programas se cierran o reconfiguran solos
- se envían correos electrónicos sin el conocimiento o el consentimiento del usuario.

Métodos de infiltración

Ingeniería social

La ingeniería social es la manipulación a las personas para que realicen acciones o divulguen información confidencial. Los ingenieros sociales con frecuencia dependen de la disposición de las personas para ayudar, pero también se aprovechan de sus vulnerabilidades. Por ejemplo, un atacante llamará a un empleado autorizado con un problema urgente que requiere acceso inmediato a la red y apelará a la vanidad o la codicia del empleado o invocará la autoridad mediante el uso de técnicas de eliminación de nombres para obtener este acceso.



Algunos tipos comunes de ataques de ingeniería social

- **Pretexto:** Esto es cuando un atacante llama a una persona y miente en el intento de obtener acceso a datos privilegiados. Por ejemplo, fingir que necesita los datos personales o financieros de una persona para confirmar su identidad.
- **Infiltración (tailgating):** Esto es cuando un atacante sigue rápidamente a una persona autorizada a un lugar seguro.

- **Una cosa por otra (quid pro quo):** Esto sucede cuando un hacker solicita información personal de una parte a cambio de algo, como un regalo gratis.

Denegación de servicio

Los ataques de denegación de servicio (DoS) son un tipo de ataque de red que es relativamente sencillo de llevar a cabo, incluso por parte de un atacante no cualificado. Un ataque DoS da como resultado cierto tipo de interrupción del servicio de red a los usuarios, los dispositivos o las aplicaciones.

Los dos tipos principales de ataques DoS

Cantidad abrumadora de tráfico: Esto es cuando se envía una gran cantidad de datos a una red, a un host o a una aplicación a una velocidad que no pueden procesar. Esto ocasiona una disminución de la velocidad de transmisión o respuesta o una falla en un dispositivo o servicio.

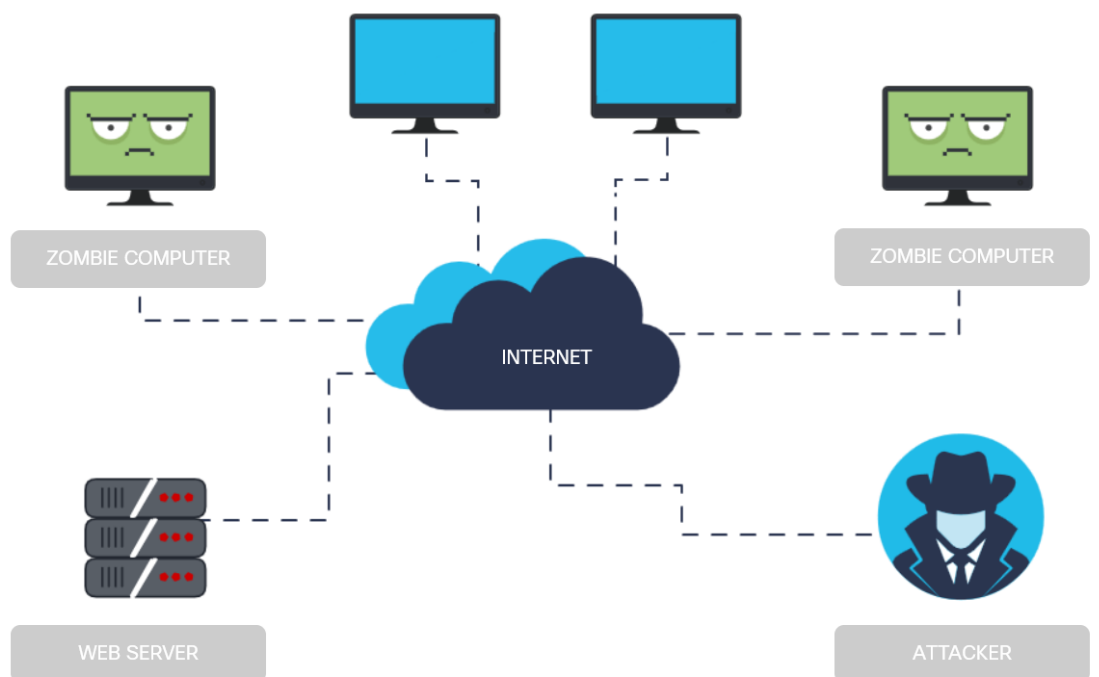
Paquetes malicioso formateados: Un paquete es una colección de datos que fluye entre una computadora o aplicación de origen y una receptora a través de una red, como Internet. Cuando se envía un paquete con formato malicioso, el receptor no puede manejarlo. Por ejemplo, si un atacante reenvía paquetes que contienen errores o paquetes formateados incorrectamente que no pueden ser identificados por una aplicación, esto hará que el dispositivo receptor funcione muy lentamente o se bloquee.

Los ataques de DoS se consideran un riesgo importante porque pueden interrumpir fácilmente la comunicación y causar una pérdida significativa de tiempo y dinero.

DoS distribuido

Un ataque DoS distribuido (DDoS) es similar a un ataque DoS pero proviene de múltiples fuentes coordinadas. Por ejemplo:

- Un atacante crea una red (botnet) de hosts infectados llamados zombies, que son controlados por sistemas de manejo.
- Las computadoras zombis constantemente analizan e infectan más hosts, creando más y más zombis.
- Cuando está listo, el hacker proporciona instrucciones a los sistemas manipuladores para que los botnet de zombies lleven a cabo un ataque de DDoS.

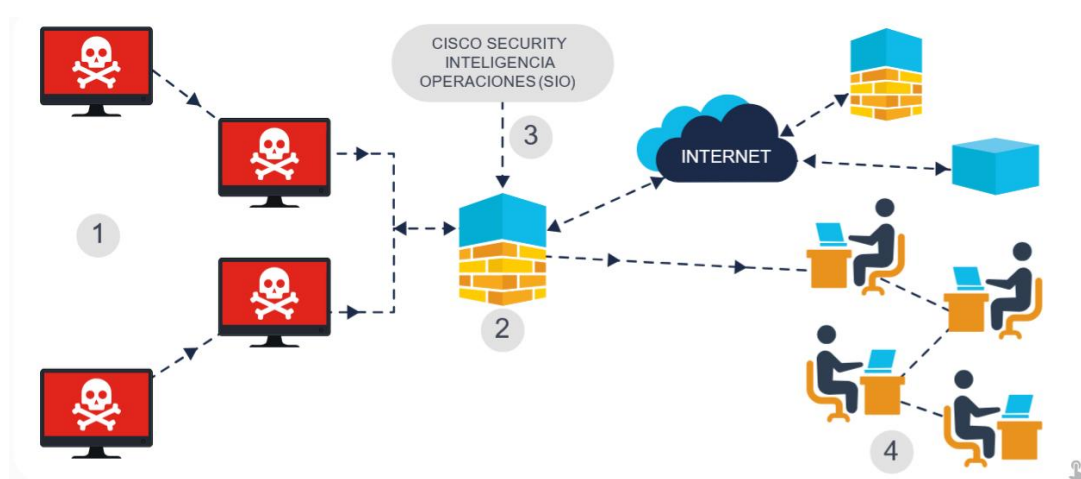


Botnet

Una computadora bot se infecta generalmente por visitar un sitio web, abrir un elemento adjunto de correo electrónico o abrir un archivo de medios infectado. Una botnet es un grupo de bots, conectados a través de Internet, que pueden ser controlados por un individuo o grupo malintencionado. Puede tener decenas de miles, o incluso cientos de miles, de bots que normalmente se controlan a través de un servidor de comando y control.

Estos bots se pueden activar para distribuir malware, lanzar ataques DDoS, distribuir correo electrónico no deseado o ejecutar ataques de contraseña por fuerza bruta. Los ciberdelincuentes suelen alquilar botnets a terceros con fines nefastos.

Muchas organizaciones, como Cisco, fuerzan las actividades de red a través de filtros de tráfico de botnet para identificar cualquier ubicación de botnet.



1. Los bots infectados intentan comunicarse con un host de comando y control Internet.
2. El filtro de botnet de Firewall de Cisco es una función que detecta el tráfico proveniente de dispositivos infectados con el código de botnet malicioso.
3. El servicio Cisco Security Intelligence Operations (SIO) basado en la nube envía filtros actualizados al firewall que coinciden con el tráfico de las nuevas botnets conocidas.
4. Las alertas se envían al equipo de seguridad interno de Cisco para notificarles sobre los dispositivos infectados que generan tráfico malicioso para que puedan prevenirlos, mitigarlos y remediarlos.

Ataques en el camino

Los atacantes en ruta interceptan o modifican las comunicaciones entre dos dispositivos, como un navegador web y un servidor web, ya sea para recopilar información de uno de los dispositivos o para hacerse pasar por uno de ellos. Este tipo de ataque también se conoce como ataque de **hombre en el medio** o de **hombre en el móvil**.

Un ataque MiTM ocurre cuando un ciberdelincuente toma el control de un dispositivo sin que el usuario lo sepa. Con ese nivel de acceso, el atacante puede interceptar y capturar información sobre el usuario antes de retransmitirla a su destino. Estos tipos de ataques se utilizan a menudo para robar información financiera. Hay muchos tipos de malware que poseen capacidades de ataque MiTM.



Una variación del hombre en el medio, el MitMo es un tipo de ataque utilizado para tomar el control de un dispositivo móvil. Cuando está infectado, el dispositivo móvil recibe instrucciones de filtrar información confidencial del usuario y enviarla a los atacantes. ZeUS es un ejemplo de paquete de malware con capacidades MitMO. Permite a los atacantes capturar silenciosamente los mensajes

SMS de verificación en dos pasos que se envían a los usuarios.

Envenenamiento SEO

Probablemente hayas oído hablar de la optimización de motores de búsqueda o SEO que, en términos simples, se trata de mejorar el sitio web de una organización para que gane una mayor visibilidad en los resultados de los motores de búsqueda.



Los motores de búsqueda como Google funcionan presentando una lista de páginas web a los usuarios en función de su consulta de búsqueda. Estas páginas web se clasifican de acuerdo con la relevancia de su contenido.

Aunque muchas empresas legítimas se especializan en la optimización de sitios web para mejorar su posición, los atacantes utilizan el SEO para hacer que un sitio web malicioso aparezca más arriba en los resultados de la búsqueda. Esta técnica se denomina envenenamiento SEO.

El objetivo más común del envenenamiento de SEO es aumentar el tráfico a sitios maliciosos que pueden albergar malware o intentar ingeniería social.

Ataques de contraseña

La introducción de un nombre de usuario y una contraseña es una de las formas más populares de autenticarse en un sitio web. Por lo tanto, descubrir su contraseña es una forma fácil para que los ciberdelincuentes accedan a su información más valiosa.

Pulverización de contraseñas

Esta técnica intenta obtener acceso a un sistema «rociando» algunas contraseñas de uso común en un gran número de cuentas. Por ejemplo, un ciberdelincuente utiliza «Password123» con muchos nombres de usuario antes de volver a intentarlo con una segunda contraseña de uso común, como «qwerty». Esta técnica permite que el perpetrador permanezca sin ser detectado, ya que evita los bloqueos frecuentes de la cuenta.



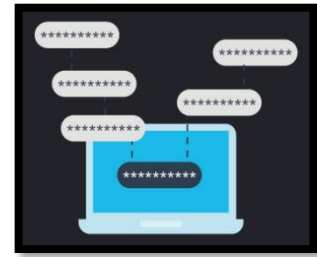
Ataques de diccionario

Un hacker intenta sistemáticamente todas las palabras de un diccionario o una lista de palabras de uso común como contraseña en un intento de ingresar a una cuenta protegida con contraseña.



Ataques por fuerza bruta

Son la forma más simple y utilizada de obtener acceso a un sitio protegido con contraseña. Los ataques de fuerza bruta ven a un atacante utilizando todas las combinaciones posibles de letras, números y símbolos en el espacio de contraseñas hasta que lo hacen bien.



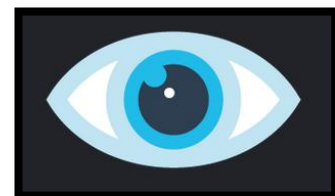
Ataques arco iris

Las contraseñas de un sistema informático no se almacenan como texto sin formato, sino como valores con hash (valores numéricos que identifican datos de forma única). Una tabla arcoíris es un gran diccionario de valores hash precalculados y las contraseñas a partir de las cuales se calcularon. A diferencia de un ataque de fuerza bruta que tiene que calcular cada hash, un ataque de arco iris compara el hash de una contraseña con los almacenados en la tabla rainbow. Cuando un atacante encuentra una coincidencia, identifica la contraseña utilizada para crear el hash.



Interceptación de tráfico

El texto sin formato o las contraseñas sin cifrar pueden ser leídas fácilmente por otras personas y máquinas al interceptar las comunicaciones. Si almacena una contraseña en texto claro y legible, cualquier persona que tenga acceso a su cuenta o dispositivo, ya sea autorizado o no, podrá leerlo.



Amenazas persistentes avanzadas

Los atacantes también logran infiltrarse a través de amenazas persistentes avanzadas (APT): una operación avanzada, sigilosa, de múltiples fases y a largo plazo contra un objetivo específico. Por estas razones, un atacante individual a menudo carece de las habilidades, los recursos o la persistencia para realizar APTs.

Debido a la complejidad y al nivel de habilidad requerido para llevar a cabo un ataque de este tipo, una APT generalmente está bien financiada y generalmente apunta a organizaciones o naciones por razones comerciales o políticas.

Su objetivo principal es implementar malware personalizado en uno o más de los sistemas del objetivo y permanecer allí sin ser detectado.

Aprovechamiento de las vulnerabilidades de seguridad

Vulnerabilidades de hardware

Las vulnerabilidades de hardware se presentan a menudo mediante defectos de diseño del hardware. Por ejemplo, el tipo de memoria denominada RAM consiste básicamente en muchos condensadores (un componente que puede contener una carga eléctrica) instalados muy cerca unos de otros. Sin embargo, pronto se descubrió que, debido a su proximidad, los cambios aplicados a uno de estos condensadores podrían influir en los condensadores vecinos. Por esta falla de diseño, se generó un exploit llamada Rowhammer. Al acceder repetidamente (martillar) a una fila de memoria, el exploit Rowhammer desencadena interferencias eléctricas que eventualmente corrompen los datos almacenados dentro de la RAM.

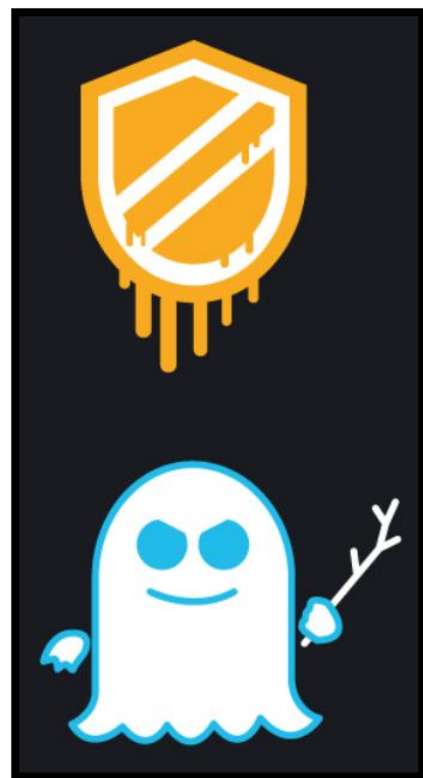
Meltdown y Spectre

Los investigadores de seguridad de Google descubrieron Meltdown y Spectre, dos vulnerabilidades de hardware que afectan a casi todas las unidades de procesamiento central (CPU) lanzadas desde 1995 en computadoras de escritorio, computadoras portátiles, servidores, teléfonos inteligentes, dispositivos inteligentes y servicios en la nube.

Los atacantes que explotan estas vulnerabilidades pueden leer toda la memoria de un sistema determinado (Meltdown), así como los datos manejados por otras aplicaciones (Spectre). Las explotaciones de vulnerabilidad Meltdown y Spectre se denominan ataques de canal lateral (la información

se obtiene de la implementación de un sistema informático). Tienen la capacidad de comprometer grandes cantidades de datos de memoria porque los ataques se pueden ejecutar varias veces en un sistema con muy pocas posibilidades de que se produzca un bloqueo u otro error.

Las vulnerabilidades de hardware son específicas de los modelos de dispositivos y generalmente no se ven atacadas por intentos comprometedores aleatorios. Si bien las



vulnerabilidades de hardware son más comunes en ataques altamente dirigidos, la protección tradicional contra malware y una buena seguridad física son una protección suficiente para el usuario cotidiano.

Vulnerabilidades de software

Las vulnerabilidades de software suelen ser provocadas por errores en el sistema operativo o en el código de la aplicación.

Caso: La vulnerabilidad SynFUL Knock permitió a los atacantes obtener el control de los enrutadores de nivel empresarial, como los enrutadores ISR de Cisco, desde los cuales podían monitorear todas las comunicaciones de red e infectar otros dispositivos de red.

Esta vulnerabilidad se introdujo en el sistema cuando una versión alterada de IOS se instaló en los routers. Para evitar esto, verifique siempre la integridad de la imagen de IOS descargada y limite el acceso físico al equipo solo al personal autorizado.

Categorización de vulnerabilidades de software

La mayoría de las vulnerabilidades de seguridad del software se dividen en varias categorías principales.

Desbordamiento de búfer: Los búferes son áreas de memoria asignadas a una aplicación. Se produce una vulnerabilidad cuando los datos se escriben más allá de los límites de un búfer. Al cambiar los datos más allá de los límites de un búfer, la aplicación puede acceder a la memoria asignada a otros procesos. Esto puede provocar un bloqueo del sistema o comprometer los datos, o proporcionar una escalada de privilegios.



Entrada no validada: Los programas a menudo requieren la entrada de datos, pero estos pueden tener contenido malicioso, diseñado para obligar al programa a comportarse de forma no deseada. Por ejemplo, considere un programa que recibe una imagen para procesarla. Un usuario malintencionado podría crear un archivo de imagen con dimensiones de imagen no válidas. Las dimensiones creadas maliciosamente podrían forzar al programa a asignar búferes de tamaños incorrectos e imprevistos.



Condiciones de carrera: Esta vulnerabilidad describe una situación en la que la salida de un evento depende de salidas ordenadas o programadas. Una condición de carrera se convierte en una fuente de vulnerabilidad cuando los eventos ordenados o cronometrados requeridos no ocurren en el orden correcto o en el momento adecuado.



Debilidad en las Prácticas de Seguridad: Los sistemas y los datos confidenciales se pueden proteger mediante técnicas como la autenticación, la autorización y el cifrado. Los desarrolladores deben ceñirse al uso de técnicas de seguridad y bibliotecas que ya hayan sido creadas, probadas y verificadas y no deben intentar crear sus propios algoritmos de seguridad. Es probable que solo introduzcan nuevas vulnerabilidades.



Problemas de Control de Acceso: El control de acceso es el proceso de controlar quién hace qué y va desde administrar el acceso físico al equipo hasta dictar quién tiene acceso a un recurso, como un archivo, y qué pueden hacer con él, como leer o cambiar el archivo. Muchas vulnerabilidades de seguridad se generan por el uso incorrecto de los controles de acceso. Casi todos los controles de acceso y las prácticas de seguridad pueden superarse si un atacante tiene acceso físico al equipo objetivo. Por ejemplo, independientemente de la configuración de permisos de un archivo, un hacker puede omitir el sistema operativo y leer los datos directamente del disco. Por lo tanto, para proteger la máquina y los datos que contiene, se debe restringir el acceso físico y se deben utilizar técnicas de cifrado para proteger los datos contra robos o corrupción.



Actualizaciones de software

El objetivo de las actualizaciones de software es mantenerse actualizado y evitar el aprovechamiento de vulnerabilidades. Microsoft, Apple y otros productores de sistemas operativos lanzan parches y actualizaciones casi todos los días y las empresas u organizaciones responsables de las aplicaciones, como los navegadores web, las aplicaciones móviles y los servidores web, suelen actualizarlas.

A pesar de que las organizaciones se esfuerzan mucho en encontrar y reparar vulnerabilidades de software, se descubren nuevas vulnerabilidades con regularidad. Es por eso que algunas organizaciones utilizan investigadores de seguridad de terceros que se especializan en encontrar vulnerabilidades en el software, o realmente invierten en sus propios equipos de pruebas de penetración dedicados a buscar, encontrar y parchear las vulnerabilidades del software antes de que puedan ser explotadas.

Project Zero de Google es un gran ejemplo de esta práctica. Después de descubrir una serie de vulnerabilidades en varios softwares utilizados por los usuarios finales, Google formó un equipo permanente dedicado a encontrar vulnerabilidades de software.

Debe estar constantemente al tanto de las vulnerabilidades de seguridad a su alrededor para poder responder en consecuencia. Pero recuerde que el panorama de la ciberseguridad evoluciona continuamente. Por ejemplo, el criptojacking, un tipo de ciberataque utilizado para extraer criptomonedas va en aumento.

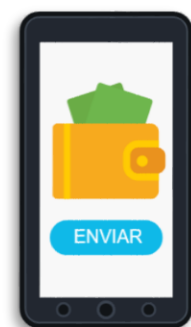
El panorama de la ciberseguridad

Criptomoneda

La criptomoneda es dinero digital que se puede utilizar para comprar bienes y servicios, utilizando técnicas de cifrado sólidas para asegurar las transacciones en línea. Los bancos, los gobiernos e incluso empresas como Microsoft y AT&T son muy conscientes de su importancia y se están sumando al tren de las criptomonedas.

¿Cómo funcionan las transacciones de criptomonedas?

Los propietarios de criptomonedas guardan su dinero en «billeteras» virtuales encriptadas. Cuando se lleva a cabo una transacción entre los propietarios de dos billeteras digitales, los detalles se registran en un registro electrónico descentralizado o en un sistema de cadena de bloques (blockchain). Esto significa que se lleva a cabo con cierto grado de anonimato y se autogestiona, sin interferencias de terceros, como bancos centrales o entidades gubernamentales.



Aproximadamente cada diez minutos, computadoras especiales recopilan datos sobre las últimas transacciones en criptomonedas, convirtiéndolas en acertijos matemáticos para mantener la confidencialidad. Estas transacciones se verifican a través de un proceso técnico y altamente complejo conocido como «minería». Este paso suele implicar a un

ejército de «mineros» que trabajan en PC de alta gama para resolver acertijos matemáticos y autenticar transacciones.

Una vez verificado, el libro mayor se actualiza y se copia y distribuye electrónicamente en todo el mundo a cualquier persona que pertenezca a la red blockchain, completando efectivamente una transacción.

Criptojackking

El criptojackking es una amenaza emergente que se esconde en la computadora, el teléfono móvil, la tableta, la computadora portátil o el servidor de un usuario, utilizando los recursos de esa máquina para «minar» criptomonedas sin el consentimiento o el conocimiento del usuario.

Está claro que el panorama cibernético está cambiando. Y si bien el auge de las criptomonedas ha generado muchas oportunidades, también expone más vulnerabilidades, lo que hace que sea más fácil que nunca para los hackers robar enormes sumas de dinero en línea.

PROTEGIENDO SUS DATOS Y SU PRIVACIDAD

Proteja sus dispositivos y su red

Protegiendo sus Dispositivos Informáticos

Sus dispositivos informáticos son el portal hacia su vida en línea, almacenando muchos de sus datos personales. Por lo tanto, es importante proteger la seguridad de sus dispositivos.

Consejos importantes sobre cómo hacerlo

- **Encienda el firewall:** Debe usar al menos un tipo de firewall (ya sea un firewall de software o un firewall de hardware en un enrutador) para proteger su dispositivo del acceso no autorizado. El firewall debe activarse y actualizarse constantemente para evitar que los hackers accedan a sus datos personales o de la organización.
- **Instale el antivirus y el antiespia:** El software malintencionado, como virus y spyware (programa espía), está diseñado para obtener acceso no autorizado a su equipo y a sus datos. Una vez instalados, los virus pueden destruir los datos y ralentizar el equipo. Incluso pueden tomar su computadora y emitir correos electrónicos no deseados con su cuenta. El spyware puede supervisar sus actividades en línea, recopilar su información personal o enviar anuncios emergentes no deseados a su navegador

web mientras está en línea. Para evitarlo, solo debe descargar software de sitios web de confianza. Sin embargo, siempre debe utilizar un software antivirus para proporcionar otra capa de protección. El software, que usualmente incluye antispyware, está diseñado para analizar su computadora y correo electrónico entrante para detectar virus y eliminarlos. Mantener su software actualizado protegerá a su computadora de cualquier software malicioso reciente.

- **Administre su sistema operativo o navegador web:** Los hackers siempre intentan aprovechar las vulnerabilidades que pueden existir en su sistema operativo (como Microsoft Windows o macOS) o en el navegador web (como Google Chrome o Apple Safari). De este modo, para proteger su computadora y sus datos, debe establecer la configuración de seguridad en su computadora o navegador a un nivel medio o alto. También debe actualizar el sistema operativo de la computadora, incluyendo los navegadores web, y descargue e instale periódicamente parches y actualizaciones de seguridad del software de los proveedores.
- **Configure la protección de contraseñas:** Todos sus dispositivos informáticos, ya sean ordenadores, computadoras portátiles, tabletas o teléfonos inteligentes, deben estar protegidos con contraseña para evitar el acceso no autorizado. Cualquier información almacenada debe estar cifrada, especialmente en el caso de datos sensibles o confidenciales. Solo debe almacenar la información necesaria en su dispositivo móvil, en caso de que se lo roben o se pierda. Recuerde, si alguno de sus dispositivos se ve comprometido, los delincuentes pueden tener acceso a todos sus datos a través del proveedor de servicios de almacenamiento en la nube, como iCloud o Google Drive.

Los dispositivos de IoT (Internet de las cosas) representan un riesgo incluso mayor que los otros dispositivos electrónicos. Mientras que las computadoras de escritorio, portátiles y los dispositivos móviles reciben actualizaciones de software frecuentes, la mayoría de los dispositivos de IdC aún tiene su software original. Si se encuentran vulnerabilidades en el software, el dispositivo de IoT es probable que se mantenga vulnerable. Y para empeorar el problema, los dispositivos IdC requieren acceso a Internet y, en la mayoría de los casos, dependen de su red local. El resultado es que cuando los dispositivos de IoT se ven comprometidos, permiten a los piratas informáticos acceder a su red y datos locales. La mejor manera de protegerse de esta situación es contar con dispositivos de IdC con una red aislada.

Seguridad de la red inalámbrica en casa

Las redes inalámbricas permiten que los dispositivos habilitados con Wi-Fi, como computadoras portátiles y tablets, se conecten a la red por medio de un identificador de red conocido como identificador de conjunto de servicios (SSID). Si bien un enrutador inalámbrico se puede configurar para que no transmita el SSID, esto no debe considerarse una seguridad adecuada para una red inalámbrica.

Los hackers conocerán el SSID preestablecido y la contraseña predeterminada. Por lo tanto, estos detalles deben cambiarse para evitar que los intrusos entren en la red inalámbrica doméstica. Además, debe encriptar la comunicación inalámbrica habilitando la seguridad inalámbrica y la función de encriptado WPA2 en el router inalámbrico. Pero tenga en cuenta que, incluso con el cifrado WPA2 habilitado, una red inalámbrica puede seguir siendo vulnerable.

Más información sobre el descubrimiento de una falla de seguridad en el protocolo WPA2 en 2017:

Esta vulnerabilidad puede ser atacada utilizando el Ataque de reinstalación de clave (KRACK, Key Reinstallation Attack) por intrusos. En términos sencillos, los atacantes rompen el cifrado entre un enrutador inalámbrico y un dispositivo inalámbrico, lo que les da acceso a los datos de la red. Esta falla afecta a todas las redes Wi-Fi modernas y protegidas.

Para mitigar esta situación, debe:

- actualizar todos los productos afectados como routers inalámbricos, computadoras portátiles y dispositivos móviles, tan pronto como las actualizaciones de seguridad estén disponibles
- usar una conexión por cable para cualquier dispositivo con una tarjeta de interfaz de red (NIC) con cable
- utilizar un servicio de red privada virtual (VPN) de confianza al acceder a una red inalámbrica

Riesgos del Wi-Fi público

Cuando está lejos de casa, puede acceder a su información online y navegar por internet a través redes inalámbricas públicas o puntos de acceso a Wi-Fi. Sin embargo, hay

algunos riesgos involucrados, lo que significa que es mejor no acceder ni enviar ninguna información personal cuando se usa una red Wi-Fi pública.

Siempre debe verificar que su dispositivo no esté configurado para compartir archivos y datos multimedia, y que requiera la autenticación de usuario con cifrado.

También debe usar un servicio de VPN encriptado para evitar que otras personas intercepten su información (lo que se conoce como «espionaje») a través de una red inalámbrica pública. Este servicio le brinda acceso seguro a Internet, al cifrar la conexión entre su dispositivo y el servidor VPN. Incluso si los hackers interceptan una transmisión de datos en un túnel VPN encriptado, no podrán descifrarla.

No olvide que el protocolo inalámbrico Bluetooth, que se encuentra en muchos teléfonos inteligentes y tabletas, también puede ser aprovechado por los hackers para espiar, establecer controles de acceso remoto, distribuir malware y agotar las baterías. Por lo tanto, un consejo principal es mantener el Bluetooth desactivado cuando no lo esté usando.

Una Contraseña Segura

Estos son algunos consejos sencillos que le ayudarán a elegir una contraseña segura.

- 1) No use palabras del diccionario o nombres en ningún idioma.
- 2) No use errores ortográficos comunes de palabras del diccionario.
- 3) De ser posible, use caracteres especiales como ! @ # \$ % ^ & * ().
- 4) No use nombres de equipos y cuentas.
- 5) Utilice una contraseña con más de 10 caracteres.

Uso de una frase de contraseña

Para evitar el acceso no autorizado a sus dispositivos, debería considerar el uso de frases de contraseña en lugar de contraseñas. Por lo general, una frase de contraseña adopta la forma de una oración ('Acat th @tlov3sd0gs. '), lo que hace que sea más fácil recordarla. Y dado que es más larga que una contraseña típica, es menos vulnerable a los ataques de diccionario o de fuerza bruta.

Estos son algunos consejos para crear una buena frase de contraseña:

-  Elija una declaración que es significativa para usted.
-  Agregue caracteres especiales.
-  Cuanto más tiempo mejor.

- ✚ Evitar declaraciones famosas, por ejemplo, letras de una canción popular.

Guías para las contraseñas

El Instituto Nacional de Normas y Tecnología (NIST) de los Estados Unidos publicó requisitos de contraseña mejorados. Las normas del NIST están destinadas a aplicaciones del gobierno, pero también pueden servir como normas para otras.

Estas pautas tienen como objetivo colocar la responsabilidad de la verificación del usuario en los proveedores de servicios y garantizar una mejor experiencia para los usuarios en general.



Ellos afirman:

- Las contraseñas deben tener por lo menos 8 caracteres, pero no más de 64.
- No utilice contraseñas comunes ni que se puedan adivinar con facilidad; por ejemplo, «contraseña», «abc123».
- No debe haber reglas de composición, como incluir números y letras mayúsculas y minúsculas.
- Los usuarios deben poder ver la contraseña al escribir, para ayudar a mejorar la precisión.
- Se deben permitir todos los caracteres de impresión y espacios.
- No debe haber sugerencias para la contraseña.
- No debe haber periodo de caducidad de contraseña.
- No debe haber autenticación basada en el conocimiento, como tener que proporcionar respuestas a preguntas secretas o verificar el historial de transacciones.

Mantenimiento de Datos

¿Qué es la encriptación?

La encriptación o cifrado es el proceso de conversión de la información a un formato que una parte no autorizada no puede leer. Solo una persona de confianza autorizada con la contraseña o clave secreta puede descifrar los datos y acceder a ellos en su formato original.

Note que la encriptación en sí misma no evita que una persona intercepte los datos. Solo puede evitar que una persona no autorizada vea o acceda al contenido. De hecho, algunos delincuentes pueden decidir simplemente encriptar sus datos y hacer que sean inutilizables hasta que usted pague un rescate.

¿Cómo se cifran sus datos?

Se utilizan programas de software para cifrar archivos, carpetas e incluso unidades enteras.

El sistema de encriptación de archivos (EFS, Encrypting File System) es una característica de Windows que permite encriptar datos. Está directamente vinculado a una cuenta de usuario específica y solo el usuario que encripta los datos podrá acceder a él después de haber sido encriptados usando EFS.

Cómo cifrar datos mediante EFS en todas las versiones de Windows:

1. Seleccione uno o más archivos o carpetas.
2. Haga clic derecho en los datos seleccionados y en **Propiedades**.
3. Busque y haga clic en «**Avanzado**».
4. Seleccione la casilla de verificación. **Encriptar contenido para proteger datos**.
5. Las carpetas y los archivos encriptados con el EFS se muestran en verde

Nota: Microsoft no incluye esta función en las versiones *Windows 10 Home* o *Windows 11 Home*; es exclusiva de las versiones *Pro*, *Enterprise* o *Education*.

Realice un respaldo de sus datos

Tener un respaldo o copia de seguridad puede evitar la pérdida de datos irremplazables, como fotos familiares. Para hacer un respaldo correcto de los datos, necesitará una ubicación de almacenamiento adicional para los datos y deberá copiar los datos en dicha ubicación periódica y automáticamente.

Algunas de estas ubicaciones de almacenamiento adicionales:

- **Red doméstica:** Almacenar sus datos localmente significa que tiene el control total de los mismos.
- **Ubicación secundaria:** Puede copiar todos sus datos en un dispositivo de almacenamiento conectado a la red (NAS), un disco duro externo simple o puede seleccionar solo algunas carpetas importantes para hacer un respaldo en unidades de memoria USB, CD/DVD o incluso cintas. En dicho escenario, usted es el

propietario y es totalmente responsable del costo y el mantenimiento de los equipos del dispositivo de almacenamiento.

- **La nube:** Puede suscribirse a un servicio de almacenamiento en la nube, como Amazon Web Services (AWS). El costo de este servicio dependerá de la cantidad de espacio de almacenamiento que necesite, por lo que es posible que deba ser más selectivo en cuanto a los datos de los que hace una copia de seguridad. Tendrá acceso a la copia de respaldo siempre y cuando tenga acceso a su cuenta. Uno de los beneficios de usar un servicio de almacenamiento en la nube es que sus datos están seguros en caso de que falle un dispositivo de almacenamiento o si experimenta una situación extrema, como un incendio o un robo.

¿Cómo se eliminan sus datos de forma permanente?

¿Alguna vez ha tenido que eliminar datos o deshacerse de un disco duro? Si es así, ¿ha tomado alguna medida de precaución para proteger los datos y evitar que caigan en malas manos?

Para borrar datos de modo que no sean recuperables, los datos deben sobrescribirse con unos y ceros varias veces, utilizando herramientas diseñadas específicamente para hacer precisamente eso. El programa SDelete de Microsoft (para Vista y versiones posteriores) reclama tener la capacidad de eliminar los archivos confidenciales por completo. Shred para Linux y Secure Empty Trash para Mac OS X afirman proporcionar un servicio similar.



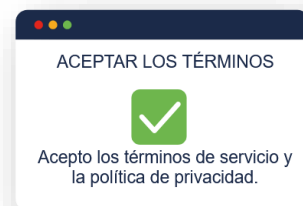
La única forma de estar seguros de que los datos o los archivos no son recuperables es destruir físicamente el disco duro o el dispositivo de almacenamiento. ¡Muchos delincuentes se han aprovechado de archivos que se consideran impenetrables o irrecuperables!

No se olvide de los datos que se pueden almacenar en línea en la nube. Dichas copias también deberán eliminarse.

¿A quién le pertenecen sus datos?

Términos del servicio

Los Términos de servicio, también conocidos como Términos de uso o Términos y condiciones, son un contrato de vinculación legal que rige las reglas de la relación entre usted, su proveedor, y otras personas que utilizan el servicio.



Comprenda los términos

Los Términos de servicio incluirán una serie de secciones, desde los derechos y responsabilidades del usuario hasta las exenciones de responsabilidad y los términos de modificación de la cuenta.

- ✓ La **política de uso de datos** describe cómo el proveedor de servicios recopilará, usará y compartirá sus datos.
- ✓ La **configuración de privacidad** le permite controlar quién ve información sobre usted y quién puede acceder a los datos de su perfil o cuenta.
- ✓ La **política de seguridad** describe lo que la empresa está haciendo para proteger los datos que obtiene de usted.

Antes de registrarse

Los factores que debe tener en cuenta antes de suscribirse a un servicio en línea son:

- ¿Ha leído el acuerdo de los términos de servicio?
- ¿Cuáles son sus derechos en relación con sus datos?
- ¿Puede solicitar una copia de sus datos?
- ¿Qué puede hacer el proveedor con los datos que usted carga?
- ¿Qué sucede con sus datos cuando cierra su cuenta?

Proteja sus datos

Para proteger sus datos y proteger su cuenta, debe:

- leer siempre los Términos de servicio cuando se registre para un nuevo servicio y decida si vale la pena renunciar a sus derechos sobre sus datos por el servicio
- seleccionar su configuración de privacidad en lugar de aceptar la configuración predeterminada
- limitar el grupo de personas con las que compartes contenido

- revisar la política de seguridad del proveedor de servicios para comprender lo que están haciendo para proteger sus datos
- cambiar sus contraseñas periódicamente, usar una contraseña compleja y una autenticación de dos factores para proteger su cuenta.

Protección de la privacidad en línea

Autenticación en Dos Factores

Los servicios en línea más populares, como Google, Facebook, Twitter, LinkedIn, Apple y Microsoft, utilizan la autenticación de dos factores para agregar una capa adicional de seguridad para los inicios de sesión de la cuenta.

Además del nombre de usuario y la contraseña, o un patrón o número de identificación personal (PIN), la autenticación de dos factores requiere un segundo token para verificar tu identidad. Esto puede ser:

- objeto físico como una tarjeta de crédito, teléfono móvil o llavero
- escaneo biométrico como huellas digitales o reconocimiento de voz o de rostro
- código de verificación enviado por SMS o correo electrónico.

Incluso con la autenticación de dos factores, los hackers aún pueden obtener acceso a sus cuentas en línea mediante ataques tales como suplantación de identidad o phishing, malware e ingeniería social.

Autorización abierta

Open Authorization (OAuth) es un protocolo de estándar abierto que permite que las credenciales de los usuarios finales tengan acceso a aplicaciones de terceros sin exponer las contraseñas de los usuarios.

Ejemplo de cómo funciona esto:

- Está deseando inscribirse en «Cybersecurity Essentials» de Cisco, el próximo curso de esta serie, que lo ayudará a desarrollar su carrera. Sin embargo, debe iniciar sesión en el portal de eLearning para hacerlo.
- No puedes recordar tus datos de inicio de sesión, pero está bien. El portal le da la opción de iniciar sesión con sus credenciales de un sitio web de redes sociales como Facebook o a través de otra cuenta como Google.

- Por lo tanto, en lugar de tener que restablecer sus datos de inicio de sesión, usted inicia sesión en el portal de aprendizaje electrónico con sus cuentas de redes sociales existentes y se registra en su próximo curso con facilidad. ¡No puede esperar para empezar!

Social Sharing (compartir en redes sociales)

Para proteger su privacidad en las redes sociales, es importante compartir la menor cantidad de información personal posible. Debe verificar las configuraciones de sus redes sociales para permitir que solo las personas que conoce vean sus actividades o participen en sus conversaciones. Mientras más información personal comparta en línea, más fácil será para alguien crear un perfil sobre usted y aprovecharse de usted en línea o fuera de ella.

Privacidad de correo electrónico y navegadores web

Estos problemas pueden minimizarse habilitando el modo de navegación privada en el navegador web. La mayoría de los exploradores web populares tienen un nombre propio para el modo de navegación privada:

- **Microsoft Internet Explorer:** InPrivate
- **Google Chrome:** Incognito
- **Mozilla Firefox:** Pestaña o ventana privadas
- **Safari:** Navegación privada

Cuando el modo privado está habilitado, las cookies (archivos guardados en su dispositivo para indicar qué sitios web ha visitado) se desactivan. Por lo tanto, todos los archivos temporales de Internet se eliminan y el historial de navegación se elimina cuando cierra la ventana o el programa. Esto puede ayudar a evitar que otros recopilen información sobre sus actividades en línea y traten de tentarlo a comprar algo con anuncios dirigidos.

Incluso con la navegación privada habilitada y las cookies desactivadas, las empresas desarrollan diferentes maneras de identificar usuarios para recopilar información y seguir el comportamiento de los usuarios. Por ejemplo, los dispositivos intermediarios, como los routers, pueden tener información sobre el historial de navegación web del usuario.

PROTEGIENDO A LA ORGANIZACIÓN

Dispositivos de Ciberseguridad y Tecnología

Dispositivos de seguridad

Los dispositivos de seguridad pueden ser dispositivos independientes como un enrutador o herramientas de software que se ejecutan en un dispositivo de red. Se dividen en seis categorías generales.

- **Routers:** Si bien los enrutadores se utilizan principalmente para interconectar varios segmentos de red, generalmente también proporcionan capacidades básicas de filtrado de tráfico. Esta información puede ayudarlo a definir qué equipos de un segmento de red determinado pueden comunicarse con qué segmentos de red.
- **Cortafuegos:** Los firewalls pueden analizar más a fondo el tráfico de red en sí e identificar comportamientos maliciosos que deben bloquearse. Los firewalls pueden tener políticas de seguridad sofisticadas aplicadas al tráfico que los atraviesa.
- **Sistema de prevención de intrusiones:** Los sistemas IPS utilizan un conjunto de firmas que coinciden y bloquean el tráfico y los ataques maliciosos.
- **Redes privadas virtuales:** Los sistemas VPN permiten que los empleados remotos usen un túnel cifrado seguro desde su computadora móvil y se conecten de forma segura a la red de la organización. Los sistemas VPN también pueden interconectar de forma segura las sucursales con la red de la oficina central.
- **Antimalware o antivirus:** Estos sistemas utilizan firmas o análisis de comportamiento de las aplicaciones para identificar y bloquear la ejecución de código malicioso.
- **Otros dispositivos de seguridad:** Otros dispositivos de seguridad incluyen dispositivos de seguridad web y de correo electrónico, dispositivos de descifrado, servidores de control de acceso de clientes y sistemas de gestión de seguridad.

Cortafuegos (firewalls)

En las redes de computadoras, un firewall está diseñado para controlar o filtrar qué comunicaciones se permiten dentro y cuáles se permiten fuera de un dispositivo o red. Se puede instalar un firewall en una sola computadora con el propósito de proteger esa computadora (firewall basado en host) o puede ser un dispositivo de red independiente

que protege una red completa de computadoras y todos los dispositivos host en esa red (firewall basado en red).

A medida que los ataques informáticos y de red se han vuelto más sofisticados, se han desarrollado nuevos tipos de cortafuegos que sirven para diferentes propósitos.

Tipos de cortafuegos comunes:

- **Cortafuegos de la capa de red:** Esto filtra las comunicaciones según las direcciones IP de origen y destino.
- **Cortafuegos de la capa de transporte:** Filtra las comunicaciones según los puertos de datos de origen y destino, así como los estados de conexión.
- **Cortafuegos de la capa de aplicación:** Filtra las comunicaciones en función de una aplicación, programa o servicio.
- **Cortafuegos de capa sensible al contexto:** Filtra las comunicaciones según el usuario, el dispositivo, la función, el tipo de aplicación y el perfil de amenaza.
- **Servidor proxy:** Filtra las solicitudes de contenido web, como URL, nombres de dominio y tipos de medios.
- **Servidor proxy inverso:** Colocados frente a servidores web, los servidores proxy inversos protegen, ocultan, descargan y distribuyen el acceso a los servidores web.
- **Cortafuegos de traducción de direcciones de red (NAT):** Este cortafuegos oculta o enmascara las direcciones privadas de los hosts de la red.
- **Firewall basado en el host:** Filtra puertos y llamadas de servicio del sistema en un solo sistema operativo de computadora.

Análisis de puertos

En redes, a cada aplicación que se ejecuta en un dispositivo se le asigna un identificador llamado número de puerto. Este número de puerto se utiliza en ambos extremos de la transmisión para asegurar que los datos estén llegando a la aplicación correcta. El escaneo de puertos es un proceso de comprobación de una computadora, un servidor u otro host de red para conocer los puertos abiertos. Puede usarse maliciosamente como una herramienta de reconocimiento para identificar el sistema operativo y los servicios que se ejecutan en una computadora o host, o un administrador de red puede usarlo de manera inofensiva para verificar las políticas de seguridad de la red.

Sistemas de detección y prevención de intrusiones

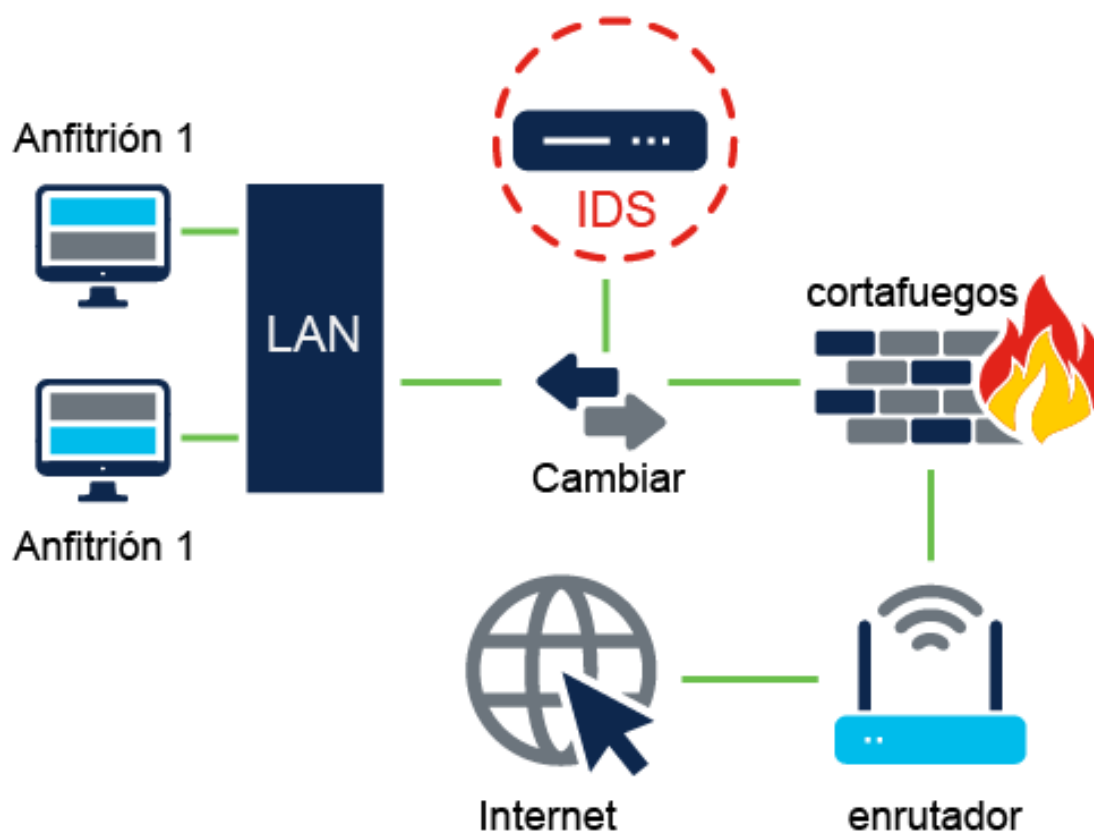
Los sistemas de detección de intrusiones (IDS) y los sistemas de prevención de intrusiones (IPS) son medidas de seguridad implementadas en una red para detectar y prevenir actividades maliciosas.

Sistemas de detección de intrusiones (IDS)

Un IDS puede ser un dispositivo de red dedicado o una de varias herramientas en un servidor, firewall o incluso un sistema operativo de computadora host, como Windows o Linux, que escanea datos contra una base de datos de reglas o firmas de ataques, en busca de tráfico malicioso.

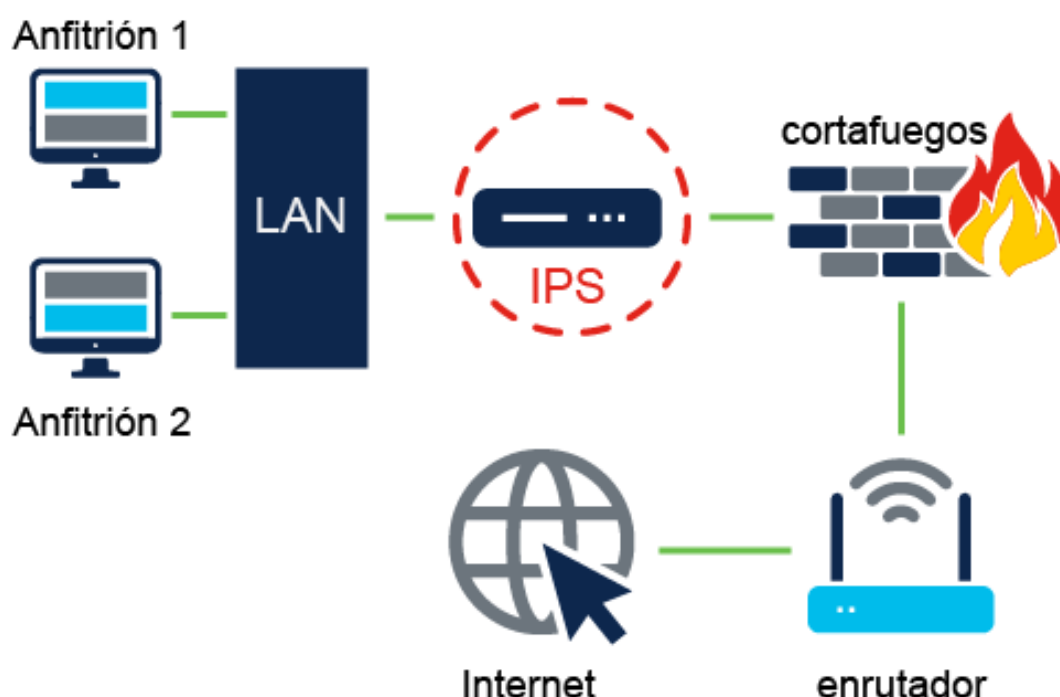
Si se detecta una coincidencia, el IDS registrará la detección y creará una alerta para un administrador de red. No tomará medidas y, por lo tanto, no evitará que ocurran ataques. El trabajo del IDS es simplemente detectar, registrar y generar informes.

El análisis que realiza el IDS ralentiza la red (esto se denomina latencia). Para evitar retrasos en la red, un IDS generalmente se coloca fuera de línea, separado del tráfico de red normal. Los datos se copian o duplican mediante un switch y luego se reenvían a los IDS para la detección sin conexión.



Sistemas de prevención de intrusiones (IPS)

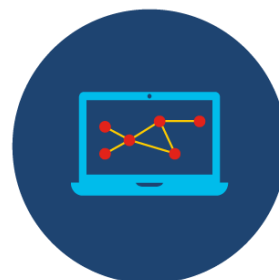
Un IPS puede bloquear o denegar el tráfico según una regla positiva o una coincidencia de firma. Uno de los IPS/IDS más reconocidos es Snort. La versión comercial de Snort es Sourcefire de Cisco. Sourcefire tiene la capacidad de realizar el análisis de tráfico y puerto en tiempo real, registrar, buscar y comparar contenido; puede detectar sondas, ataques y escaneos de puertos. También se integra con otras herramientas de terceros para informes, rendimiento y análisis de registros.



Detección en tiempo real

Hoy en día, muchas organizaciones no pueden detectar ataques hasta días o incluso meses después de que ocurran.

La detección de ataques en tiempo real requiere un análisis activo de ataques mediante el uso de firewall y dispositivos de red IDS / IPS. También se debe utilizar la detección de malware de servidor y cliente de próxima generación con conexiones a centros de amenazas globales en línea. En la actualidad, el software y los



dispositivos de análisis activos deben detectar anomalías de red mediante la detección de comportamientos y el análisis basado en el comportamiento.



DDoS es una de las mayores amenazas de ataque que requiere detección y respuesta en tiempo real. Para muchas organizaciones, los ataques DDoS que ocurren regularmente paralizan los servidores de Internet y la disponibilidad de la red. Es extremadamente difícil defenderse de estos ataques porque se originan en cientos, incluso miles, de hosts zombies, y los ataques aparecen como tráfico legítimo.

Protección contra software malicioso

Una forma de defenderse contra los ataques de día cero y las amenazas persistentes avanzadas (APT) es utilizar una solución de detección de malware avanzada de nivel empresarial, como la Red de amenazas de protección contra malware avanzada (AMP) de Cisco.

Este es un software de cliente / servidor que se puede implementar en puntos finales de host, como un servidor independiente o en otros dispositivos de seguridad de red. Analiza millones de archivos y los correlaciona con cientos de millones de otros artefactos de malware analizados en busca de comportamientos que revelen una APT. Este enfoque proporciona una visión global de los ataques de malware, las campañas y su distribución.

Beneficios de Threat Grid de Cisco:

- ***Equipo del centro de operaciones seguras:*** Threat Grid permite al equipo de Cisco Secure Operations Center recopilar datos más precisos y procesables.
- ***Equipo de respuestas a incidentes:*** Por lo tanto, el equipo de respuesta a incidentes tiene acceso a información forense sólida a partir de la cual puede analizar y comprender más rápidamente los comportamientos sospechosos.
- ***Equipo de inteligencia de amenazas:*** Con este análisis, el equipo de inteligencia de amenazas puede mejorar de manera proactiva la infraestructura de seguridad de la organización.
- ***Equipo de ingeniería de infraestructura de seguridad:*** En general, el equipo de ingeniería de infraestructura de seguridad puede consumir y actuar sobre la información de amenazas más rápido, a menudo de forma automatizada.

Mejores prácticas de seguridad

Muchas organizaciones nacionales y profesionales han publicado listas de buenas prácticas de seguridad. Algunas de las pautas más útiles se encuentran en repositorios organizacionales como el Centro de recursos de seguridad informática del Instituto Nacional de Estándares y Tecnología (NIST).

- **Realizar una evaluación de riesgos:** Conocer y comprender el valor de lo que está protegiendo ayudará a justificar los gastos de seguridad.
- **Crea una política de seguridad:** Cree una política que describa claramente las reglas, los roles laborales y las responsabilidades y expectativas de los empleados de la organización.
- **Medidas de seguridad físicas:** Restrinja el acceso a los armarios de redes y a ubicaciones del servidor, así como a la extinción de incendios.
- **Medidas de seguridad de recursos humanos:** Las verificaciones de antecedentes deben completarse para todos los empleados.
- **Realice y pruebe copias de seguridad:** Realice copias de seguridad de la información con regularidad y pruebe la recuperación de datos a partir de copias de seguridad.
- **Mantenga actualizaciones y parches de seguridad:** Actualice periódicamente los programas y sistemas operativos de servidor, cliente y dispositivo de red.
- **Emplee controles de acceso:** Configure los roles de usuario y los niveles de privilegio, así como una autenticación de usuario sólida.
- **Pruebe regularmente la respuesta de incidentes:** Utilice un equipo de respuesta ante incidentes y pruebe los escenarios de respuesta ante emergencias.
- **Implemente una herramienta de administración, análisis y monitoreo de redes:** Elija una solución de monitoreo de seguridad que se integre en otras tecnologías.
- **Implemente dispositivos de seguridad de red:** Utilice enrutadores, firewalls y otros dispositivos de seguridad de próxima generación.
- **Implemente una solución integral de seguridad de endpoints:** Utilice software antivirus y antimalware en el nivel de la empresa.
- **Eduque a los usuarios:** Proporcione capacitación a los empleados en procedimientos de seguridad. Una de las organizaciones más conocidas y respetadas para la capacitación en ciberseguridad es el SANS Institute.
- **Cifrar datos:** Cifre todos los datos organizativos confidenciales, incluido el correo electrónico.

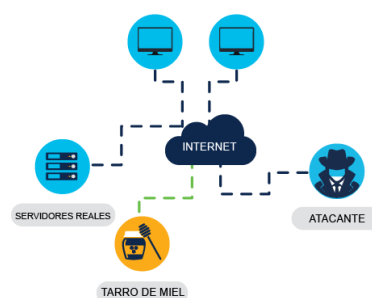
Enfoque de comportamiento de ciberseguridad

Seguridad basada en el comportamiento

La seguridad basada en el comportamiento es una forma de detección de amenazas que implica capturar y analizar el flujo de comunicación entre un usuario en la red local y un destino local o remoto. Cualquier cambio en los patrones normales de comportamiento se considera anomalía y puede indicar un ataque.

Dos herramientas de detección basadas en el comportamiento:

Honeypot: Es una herramienta de detección basada en el comportamiento que atrae al atacante apelando a su patrón predicho de comportamiento malicioso. Una vez que el atacante está dentro del honeypot, el administrador de la red puede capturar, registrar y analizar su comportamiento para poder construir una mejor defensa.



Arquitectura de la solución Cisco Cyber Threat

Defense: Esta arquitectura de seguridad utiliza detección e indicadores basados en el comportamiento para proporcionar mayor visibilidad, contexto y control. El objetivo es saber quién está llevando a cabo el ataque, qué tipo de ataque están realizando y dónde, cuándo y cómo

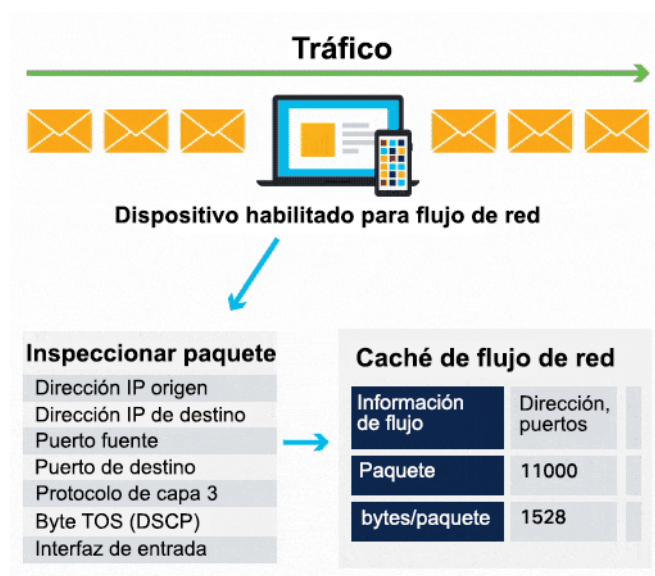
se está produciendo el ataque. Esta arquitectura de seguridad utiliza muchas tecnologías de seguridad para lograr este objetivo.

NetFlow

La tecnología NetFlow se utiliza para recopilar información sobre los datos que fluyen a través de una red, incluidos quiénes y qué dispositivos están en la red, y cuándo y cómo los usuarios y los dispositivos acceden a la red.

NetFlow es un componente importante del análisis y la detección basados en el comportamiento. Los conmutadores, enrutadores y firewalls equipados con NetFlow pueden reportar información sobre la entrada, salida y viaje de datos a través de la red.

Esta información se envía a los recopiladores de NetFlow que recopilan, almacenan y analizan datos de NetFlow, que se pueden utilizar para establecer comportamientos de referencia en más de 90 atributos, como la dirección IP de origen y destino.



Pruebas de Penetración

Las pruebas de penetración son el acto de evaluar un sistema informático, una red o una organización en busca de vulnerabilidades de seguridad. Una prueba de penetración busca violar los sistemas, las personas, los procesos y el código para descubrir vulnerabilidades que podrían explotarse. Esta información se utiliza para mejorar las defensas del sistema y garantizar que pueda resistir mejor los ciberataques en el futuro.

Paso 1 (Planificación): El pentester recopila la mayor cantidad de información posible sobre un sistema o red de destino, sus posibles vulnerabilidades y exploits para usarlo en su contra. Esto implica llevar a cabo un reconocimiento pasivo o activo (huella) e investigación de vulnerabilidad.

Paso 2 (Escaneo): La prueba de penetración lleva a cabo un reconocimiento activo para sondear un sistema o red objetivo e identificar posibles debilidades que, si se explotan, podrían dar acceso a un atacante. El reconocimiento activo puede incluir:

- escaneo de puertos para identificar puntos de acceso potenciales en un sistema de destino
- análisis de vulnerabilidades para identificar posibles vulnerabilidades explotables de un objetivo en particular

- establecer una conexión activa con un destino (enumeración) para identificar la cuenta de usuario, la cuenta del sistema y la cuenta de administrador.

Paso 3 (Obtener acceso): La prueba de penetración intentará obtener acceso a un sistema de destino y rastreará el tráfico de la red, utilizando varios métodos para explotar el sistema, que incluyen:

- lanzar un exploit con una carga útil en el sistema
- traspasar las barreras físicas a los activos
- ingeniería social
- explotar las vulnerabilidades del sitio web
- explotar vulnerabilidades o configuraciones incorrectas de software y hardware
- violación de los controles de acceso de seguridad
- descifrar Wi-Fi encriptado débil.

Paso 4 (Mantener el acceso): La prueba mantendrá el acceso al objetivo para averiguar qué datos y sistemas son vulnerables a la explotación. Es importante que permanezcan sin ser detectados, por lo general, utilizando puertas traseras, caballos de Troya, rootkits y otros canales encubiertos para ocultar su presencia.

Cuando esta infraestructura esté en su lugar, la prueba procederá a recopilar los datos que considere valiosos.

Paso 5 (Análisis y reportes): La prueba de penetración proporcionará comentarios a través de un informe que recomienda actualizaciones de los productos, las políticas y la capacitación para mejorar la seguridad de la organización.

Reducción del impacto

Si bien la mayoría de las organizaciones actuales son conscientes de las amenazas de seguridad comunes y hacen un esfuerzo considerable para prevenirlas, ningún conjunto de prácticas de seguridad es infalible. Por lo tanto, las organizaciones deben estar preparadas para contener el daño si se produce una violación de la seguridad. ¡Y deben actuar rápido!

Medidas que las organizaciones deben tomar cuando se identifica una violación de la seguridad:

- **Comunicar el problema:** La comunicación genera transparencia, que es crucial para este tipo de situación. Internamente, se debe informar a todos los empleados y comunicar una llamada a la acción clara. Externamente, todos los clientes deben ser informados a través de comunicación directa y anuncios oficiales.
- **Ser sincero y responsable:** Responda a la infracción de manera honesta y genuina, asumiendo la responsabilidad cuando la organización tenga la culpa.
- **Proporcione los detalles:** Sea abierto y explique por qué se produjo la infracción y qué información se vio comprometida. En general, se espera que las organizaciones se hagan cargo de los costos de los clientes asociados con los servicios de robo de identidad requeridos como resultado de una violación de seguridad.
- **Encuentre la causa:** Tome medidas para comprender qué causó y facilitó la infracción. Esto puede implicar la contratación de expertos forenses para investigar y conocer los detalles.
- **Aplicar lecciones aprendidas:** Asegúrese de que las lecciones aprendidas de las investigaciones forenses se apliquen para evitar que se produzcan infracciones similares en el futuro.
- **Compruebe y vuelva a comprobar:** Los atacantes con frecuencia probarán dejar una puerta trasera para facilitar las infracciones futuras. Para evitar que esto suceda, asegúrese de que todos los sistemas estén limpios, no haya puertas traseras instaladas y nada más se haya visto comprometido.
- **Educación:** Sensibilice, capacite y eduque a los empleados, socios y clientes sobre cómo prevenir futuras infracciones.

No olvide que el impacto de una violación de seguridad va más allá del aspecto técnico de los datos robados o la propiedad intelectual dañada. ¡Puede tener un efecto devastador en la reputación de una organización!

¿Qué es la gestión de riesgos?

La gestión de riesgos es el proceso formal de identificar y evaluar continuamente el riesgo en un esfuerzo por reducir el impacto de las amenazas y las vulnerabilidades. No puede eliminar el riesgo por completo, pero puede determinar los niveles aceptables sopesando el impacto de una amenaza con el costo de implementar controles para mitigarla. El costo de un control nunca debe superar el valor del activo que está protegiendo.

Proceso de gestión de riesgos:

- **Encuadre al riesgo:** Identifique las amenazas que aumentan el riesgo. Las amenazas pueden incluir procesos, productos, ataques, posibles fallos o interrupciones de los servicios, percepción negativa de la reputación de una organización, responsabilidad legal potencial o pérdida de propiedad intelectual.
- **Evaluar el riesgo:** Determine la gravedad que representa cada amenaza. Por ejemplo, algunas amenazas pueden tener el potencial de paralizar a toda una organización, mientras que otras amenazas pueden ser solo inconvenientes menores. El riesgo se puede priorizar evaluando el impacto financiero (un análisis cuantitativo) o el impacto a escala en la operación de una organización (un análisis cualitativo).
- **Responder al riesgo:** Desarrolle un plan de acción para reducir la exposición general al riesgo de la organización, detallando donde se puede eliminar, mitigar, transferir o aceptar el riesgo.
- **Supervisar al riesgo:** Revise continuamente cualquier riesgo reducido mediante acciones de eliminación, mitigación o transferencia. Recuerde, no todos los riesgos se pueden eliminar, por lo que deberá monitorear de cerca cualquier amenaza que haya sido aceptada.

La experiencia en ciberseguridad tiene una gran demanda. La mayoría de las grandes organizaciones tienen Equipos de Respuesta a Incidentes de seguridad informática (CSIRT) dedicados para protegerlos de los ataques cibernéticos. Echemos un vistazo a cómo funciona esto en Cisco.

Enfoque de Cisco para la ciberseguridad

CSIRT de Cisco

Muchas organizaciones grandes tienen un Equipo de respuesta a incidentes de seguridad informática (CSIRT) para recibir, revisar y responder a los informes de incidentes de seguridad informática. Cisco CSIRT va un paso más allá y proporciona evaluación proactiva de amenazas, planificación de mitigación, análisis de tendencias de incidentes y revisión de la arquitectura de seguridad en un esfuerzo por evitar que ocurran incidentes de seguridad.

El CSIRT de Cisco adopta un enfoque proactivo, colaborando con el Foro de equipos de seguridad y respuesta a incidentes (FIRST), el Intercambio de información de seguridad

nacional (NSIE), el Intercambio de información de seguridad de defensa (DSIE) y el Centro de análisis e investigación de operaciones de DNS (DNS-OARC) para asegurarnos de estar al día con los nuevos desarrollos.

Hay varias organizaciones CSIRT nacionales y públicas, como la División CERT del Instituto de Ingeniería de Software de la Universidad Carnegie Mellon, que están disponibles para ayudar a las organizaciones y CSIRT nacionales a desarrollar, operar y mejorar sus capacidades de gestión de incidentes.



Libro de estrategias de seguridad

Una de las mejores formas de prepararse para una infracción de seguridad es prevenirla.

Las organizaciones deben brindar orientación sobre:

- cómo identificar el riesgo de ciberseguridad para los sistemas, los activos, los datos y las capacidades
- la aplicación de salvaguardias y la capacitación del personal
- un plan de respuesta flexible que minimiza el impacto y el daño en caso de una violación de la seguridad
- medidas y procesos de seguridad que deben ponerse en marcha después de una violación de la seguridad.

Toda esta información se debe recopilar en un libro de estrategias de seguridad.

Un libro de estrategias de seguridad es una colección de consultas o informes repetibles que describen un proceso estandarizado para la detección y respuesta a incidentes.

Idealmente, un manual de estrategias de seguridad debería:

- resaltar cómo identificar y automatizar la respuesta a las amenazas comunes, como la detección de máquinas infectadas con malware, la actividad de red sospechosa o los intentos de autenticación irregulares.
- describir y definir claramente el tráfico entrante y saliente.
- proporcionar información resumida, incluidas tendencias, estadísticas y recuentos.
- proporcionar acceso rápido y utilizable a estadísticas y métricas clave.
- correlacionar eventos en todas las fuentes de datos relevantes.

Herramientas para la prevención y la detección de incidentes

Estas son algunas de las herramientas utilizadas para detectar y evitar incidentes de seguridad.

- Un sistema de gestión de eventos y seguridad de información (SIEM) recopila y analiza alerta de seguridad, registros y otros datos históricos y en tiempo real de los dispositivos de seguridad en la red para facilitar la detección temprana de ataques cibernéticos.
- Un sistema de prevención de pérdida de datos (DLP) está diseñado para evitar que los datos confidenciales se roben o escapen de una red. Supervisa y protege los

datos en tres estados diferentes: datos en uso (datos a los que acceden un usuario), datos en movimiento (datos que viajan a través de la red) y datos en reposo (datos almacenados en una red o dispositivo informático).

¿SU FUTURO ESTARÁ RELACIONADO CON LA CIBERSEGURIDAD?

Cuestiones legales y éticas

Cuestiones legales en Ciberseguridad

Con el fin de protegerse contra los ataques, los profesionales de la ciberseguridad deben tener las mismas habilidades que los atacantes. Sin embargo, los profesionales de la ciberseguridad utilizan sus habilidades dentro de los límites de la ley.

Asuntos legales personales

En su vida privada, puede tener la oportunidad y las habilidades de hackear la computadora o la red de otra persona. Pero hay un viejo refrán que dice: «Solo porque puedas no significa que debas hacerlo». La mayoría de los hacks dejan huellas que se pueden rastrear hasta ti.



Los profesionales de la ciberseguridad desarrollan muchas habilidades que se pueden utilizar para bien o mal. Siempre hay una gran demanda para aquellos que optan por hacer un buen uso de sus habilidades cibernéticas dentro de los límites legales.

Asuntos legales corporativos

La mayoría de los países cuentan con leyes de ciberseguridad que las empresas y las organizaciones deben cumplir.

En algunos casos, si infringe las leyes de ciberseguridad mientras realiza su trabajo, la empresa podría ser castigada y usted podría perder su trabajo. En otros casos, podría ser procesado, multado y posiblemente condenado.



Generalmente, si tiene dudas sobre si una acción o un comportamiento pueden ser ilegales, suponga que son ilegales y no los lleve a cabo. Consulte siempre con el departamento legal o de recursos humanos de la organización.

Derecho internacional y ciberseguridad

El derecho internacional de ciberseguridad es un campo en constante evolución. Los ciberataques tienen lugar en el ciberespacio, un espacio electrónico creado, mantenido y propiedad tanto de entidades públicas como privadas. No existen fronteras geográficas tradicionales en el ciberespacio. Para complicar aún más los problemas, es mucho más fácil enmascarar el origen de un ataque en la guerra cibernética que en la guerra convencional.



La sociedad global todavía está debatiendo cuál es la mejor manera de lidiar con el ciberespacio. La práctica del país, la opinio juris (un sentido en nombre de un país de que está obligado a la ley en cuestión) y cualquier tratado redactado darán forma a la ley internacional de ciberseguridad.

Cuestiones éticas en ciberseguridad

Piense en la prueba de vulneración que llevó a cabo para una empresa. Esta prueba reveló que uno de sus colegas, que comenzó al mismo tiempo que usted, era responsable de una filtración de datos. Está pensando en no incluir esto en su informe ya que podrían traerle problemas.

Hágase las siguientes preguntas para ayudarlo a decidir cuál es el mejor curso de acción.

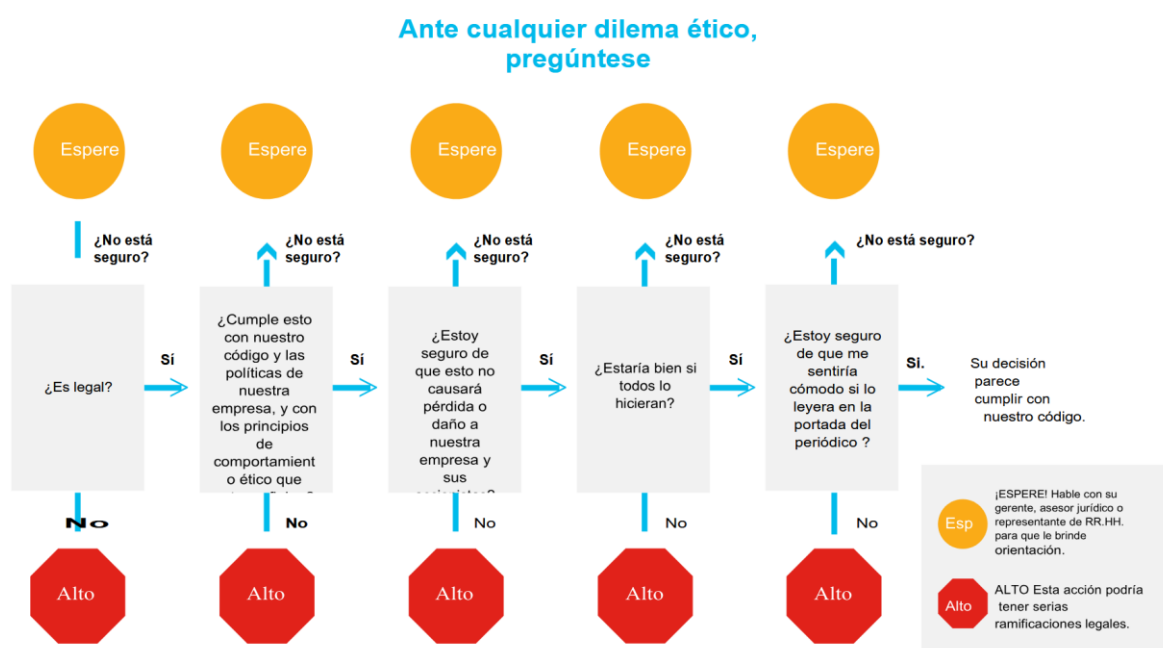
- ¿Es legal?
- ¿Su acción cumple con la política de la empresa?
- ¿Su acción será favorable para la empresa y sus partes interesadas?
- ¿Estaría bien si todos en la empresa tomaran esta medida?
- ¿El resultado de su acción mostraría a la empresa de manera positiva en un titular de noticias?

¿Cómo respondiste?

SI: Si es capaz de responder «Sí» a todas estas preguntas es probable que sea apropiado seguir adelante con su acción. Sin embargo, es importante recordar que solo porque algo es legal puede que no sea ético. En este caso, si bien retener la información del informe

de la prueba de vulneración no es ilegal, no es lo ético que se debe hacer. Las consecuencias de no denunciarlo podrían ser devastadoras para la empresa y sus clientes.

NO: Si su respuesta a cualquiera de estas preguntas es «No», debe detenerse y reconsiderar sus acciones, lo que podría tener serias ramificaciones legales para usted y la organización. En este ejemplo, tienes razón al cuestionar tus pensamientos iniciales. Cada nuevo hallazgo en ciberseguridad debe informarse para proteger a la empresa y a sus clientes. Recuerde, busque siempre el asesoramiento de su gerente directo o de un representante legal o de recursos humanos para aclarar si su acción o comportamiento pueden considerarse poco éticos.



Educación y carreras

Certificaciones profesionales

Las certificaciones de ciberseguridad son una excelente manera de verificar sus habilidades y conocimientos y también pueden impulsar su carrera.

🌐 Técnico de soporte certificado de Cisco (CCST)

Ciberseguridad: Esta certificación está dirigida a estudiantes de secundaria y de la universidad temprana, así como a aquellos interesados en un cambio de carrera.



- ✚ **CompTIA Security+**: Esta es una certificación de seguridad de nivel principiante que cumple con los requisitos de la Directiva 8570.01-M del Departamento de Defensa de los EE. UU., que es un elemento importante para cualquier persona que busque trabajar en seguridad de TI para el gobierno federal.
- ✚ **EC Council Certified Ethical Hacker (CEH)**: Esta certificación pone a prueba su comprensión y conocimiento de cómo buscar debilidades y vulnerabilidades en los sistemas de destino utilizando los mismos conocimientos y herramientas que un hacker malintencionado, pero de manera legal y legítima.
- ✚ **Profesional certificado en seguridad de los sistemas informáticos (CISSP)**: Esta es la certificación de seguridad más reconocida y popular. Para poder realizar el examen debe tener al menos cinco años de experiencia en la industria relevante.
- ✚ **Cisco Certified CyberOps Associate**: Esta certificación valida las habilidades requeridas de los analistas de ciberseguridad de nivel asociado dentro de los centros de operaciones de seguridad.

